



# **Cooperative Bank of Oromia (S.C)**

## **Internal Audit Process**

### **Risk Based IT Audit Procedure**

June 2026

## Contents

|                                                              |           |
|--------------------------------------------------------------|-----------|
| <b>PART ONE</b>                                              | <b>6</b>  |
| <b>1. Introduction</b>                                       | <b>6</b>  |
| 1.1. Preamble                                                | 6         |
| 1.2. Definitions                                             | 7         |
| 1.3. Objectives                                              | 8         |
| 1.4. Scope                                                   | 9         |
| 1.5. Governing Rules                                         | 10        |
| 1.6. Workflow                                                | 11        |
| 1.7. Duties and Responsibilities                             | 12        |
| <b>PART TWO</b>                                              | <b>17</b> |
| <b>2. Risk Based IT Audit Planning</b>                       | <b>17</b> |
| 2.1. Annual IT Audit Planning                                | 17        |
| 2.2. Engagement Planning                                     | 31        |
| 2.3. Documenting the Audit Engagement Plan and Audit Program | 35        |
| 2.4. Managing the Audit Engagement                           | 36        |
| <b>PART THREE</b>                                            | <b>38</b> |
| <b>3. Field Work</b>                                         | <b>38</b> |
| 3.1. General Overview                                        | 38        |
| 3.2. Entrance Conference                                     | 38        |
| 3.3. Audit Testing                                           | 39        |
| 3.4. IT Audit Sampling                                       | 39        |
| 3.5. Data Collection and Audit Evidence                      | 44        |
| 3.6. Using the Work of Other Auditors/Experts                | 47        |
| 3.7. Audit Finding Documentation                             | 48        |
| 3.8. Elements of the Audit Findings                          | 49        |
| 3.9. Types of Audit Findings                                 | 50        |
| 3.10. Working Paper                                          | 51        |
| 3.11. Conclusion                                             | 52        |
| 3.12. Exit Conference                                        | 53        |
| <b>Part Four</b>                                             | <b>54</b> |
| <b>4. IT Audit Reporting</b>                                 | <b>54</b> |
| 4.1. General Overview                                        | 54        |
| 4.2. Reviewing the Management Action Plan                    | 54        |
| 4.3. Audit Engagement Report                                 | 55        |
| 4.4. Semi-Annual and Annual Summary Report                   | 58        |
| 4.5. Error and Omission of Report                            | 58        |
| 4.6. Closing the Audit Engagement                            | 58        |
| <b>Part Five</b>                                             | <b>60</b> |
| <b>5. IT Audit Follow-Up</b>                                 | <b>60</b> |
| 5.1. General Overview                                        | 60        |
| 5.2. Follow up procedure                                     | 60        |
| 5.3. Reporting of follow-up                                  | 63        |
| <b>Part Six</b>                                              | <b>64</b> |
| <b>6. IT Audit Consulting Services</b>                       | <b>64</b> |
| 6.1. General Overview                                        | 64        |
| 6.2. Responsibilities of IT Auditors in Advisory Service     | 64        |
| 6.3. Planning                                                | 65        |
| 6.4. Independence and objectivity                            | 66        |
| 6.5. Due professional care                                   | 66        |
| 6.6. Engagement                                              | 67        |
| 6.7. Reporting                                               | 67        |

|                         |                                                           |           |
|-------------------------|-----------------------------------------------------------|-----------|
| 6.8.                    | Follow up .....                                           | 67        |
| <b>Part Seven.....</b>  |                                                           | <b>68</b> |
| <b>7.</b>               | <b>Quality Assurance and Continuous Improvement</b>       | <b>68</b> |
| 7.1.                    | Engagement Supervision .....                              | 68        |
| 7.2.                    | Quality Assurance .....                                   | 69        |
| 7.3.                    | Internal Assessment.....                                  | 70        |
| 7.4.                    | Auditee Satisfaction.....                                 | 72        |
| <b>Part Eight .....</b> |                                                           | <b>73</b> |
| <b>8.</b>               | <b>General Administration</b>                             | <b>73</b> |
| 8.1.                    | Recording information and keeping of working papers ..... | 73        |
| 8.2.                    | Control of Audit Records .....                            | 74        |
| 8.3.                    | Access Control and Maintenance of Audit Records.....      | 75        |
| 8.4.                    | Audit Files .....                                         | 75        |
| <b>Part Nine.....</b>   |                                                           | <b>77</b> |
| <b>9.</b>               | <b>Miscellaneous provisions</b>                           | <b>77</b> |
| 9.1.                    | Applicability of Internal Audit Procedure .....           | 77        |
| 9.2.                    | Revision of the Procedure .....                           | 77        |
| 9.3.                    | Effective Date .....                                      | 77        |

## **Acronym and Abbreviations**

|                |                                                           |
|----------------|-----------------------------------------------------------|
| <b>AI</b>      | Artificial Intelligence                                   |
| <b>CAATs</b>   | Computer-Assisted Audit Techniques                        |
| <b>CIA</b>     | Confidentiality, Integrity, Availability                  |
| <b>CIO</b>     | Chief Information Officer                                 |
| <b>CISO</b>    | Chief Information Security Officer                        |
| <b>COBIT</b>   | Control Objectives for Information and Related Technology |
| <b>DDoS</b>    | Distributed Denial of Service                             |
| <b>IIA</b>     | Institute of Internal Auditors                            |
| <b>INSA</b>    | Information Network Security Administration               |
| <b>IS</b>      | Information System                                        |
| <b>ISACA</b>   | Information Systems Audit and Control Association         |
| <b>ISP</b>     | Information System Process                                |
| <b>IT</b>      | Information Technology                                    |
| <b>ITAF</b>    | Information Technology Assurance Framework                |
| <b>KPD</b>     | Key Person Dependency                                     |
| <b>NBE</b>     | National Bank of Ethiopia                                 |
| <b>PCI-DSS</b> | Payment Card Industry Data Security Standard              |
| <b>QA</b>      | Quality Assurance                                         |
| <b>RBA</b>     | Risk Based Auditing                                       |
| <b>REF</b>     | Risk Evaluation Factors                                   |
| <b>ROI</b>     | Return on Investment                                      |
| <b>SDLC</b>    | System Development Life Cycle                             |

**Document Version 1.0**

|                                                         |                   |               |
|---------------------------------------------------------|-------------------|---------------|
| <b>Prepared by</b><br>Director of IT Audit              | <b>Signature</b>  | May 30, 2026  |
| <b>Reviewed by</b><br>Chief Internal Auditor            | <b>Signature:</b> | May 30, 2026  |
| <b>Endorsed by</b><br>Chief Executive Officer           | <b>Signature:</b> | June 06, 2026 |
| <b>Approved by</b> Chairperson of<br>Board of Directors | <b>Signature:</b> | June 13, 2026 |

## PART ONE

### 1. Introduction

#### 1.1. Preamble

**Whereas**, Information Technology (IT) has become a critical enabler of banking operations, supporting core business processes, digital service delivery, data management, and decision-making across the Bank which necessitates IT Audit scrutiny for which there must be clearly designed procedure;

**Whereas**, the increasing reliance on IT systems, coupled with evolving cyber threats, regulatory expectations, and technological innovations, necessitates a strong, independent, IT audit function to provide assurance over the effectiveness of IT governance, risk management, and internal controls that need to be guided by a series of rules;

**Whereas**, it is necessary to align IT Audit procedure with the Internal Audit Charter and internationally recognized standards and frameworks such as COBIT, ISO/IEC 27001, and ISACA IT Audit Standards;

**Whereas**, this IT Audit Procedure establishes a systematic, disciplined, and risk-based approach to IT auditing, providing auditors with practical methodology, tools, and techniques for planning, executing, and reporting IT audit engagements;

**Now, therefore**, this IT Audit Procedure is hereby established to provide the IT Audit function of the Bank with a comprehensive framework for conducting IT audit activities, ensuring consistency, quality, and alignment with best practices in IT governance and standards.

## 1.2. Definitions

- 1.2.1. **Audit engagement** is a specific audit assignment, task or review activity, such as an audit, control self-assessment review, fraud examination or consultancy. An audit engagement may include multiple tasks or activities designed to accomplish a specific set of related objectives.
- 1.2.2. **Audit program** is a step-by-step set of audit procedures and instructions that should be performed to complete an audit.
- 1.2.3. **Auditor's opinion** is a formal statement expressed by the IT Auditor or assurance professional that describes the scope of the audit, the procedures used to produce the report and whether the findings support that the audit criteria have been met.
- 1.2.4. **Audit risk** is the risk of reaching an incorrect conclusion based upon audit findings.
- 1.2.5. **Appropriate evidence** is the measure of the quality of the evidence.
- 1.2.6. **Control risk** is the risk that a material error exists that would not be prevented or detected on a timely basis by the system of internal controls (See Inherent risk).
- 1.2.7. **Detection risk** is the risk that the IS audit or assurance professional's substantive procedures will not detect an error that could be material, individually or in combination with other errors.
- 1.2.8. **Information System (IS)** is defined as the combination of strategic, managerial, and operational activities and related processes involved in gathering, processing, storing, distributing, and using information and its related technologies.
- 1.2.9. **Information Technology (IT)** is defined as the hardware, software, communication protocols, and other facilities used to input, store, process, transmit and output data in whatever form.
- 1.2.10. **Information Technology (IT) Risk:** Means a potential event that results in failure of IT and disrupting business of the Bank,
- 1.2.11. **Information Technology (IT) Audit** is a process of evaluating an organization's information technology systems, policies, and procedures to ensure effectiveness, security, and compliance.
- 1.2.12. **Integrity** is the guarding against improper information modification or destruction and includes ensuring information non-repudiation and authenticity.
- 1.2.13. **Irregularity** is violation of an established management policy or regulatory requirement. It may consist of deliberate misstatements or omission of information concerning the area under audit or the Bank's as a whole, gross negligence or unintentional illegal acts.

- 1.2.14. **Inherent risk** is the risk level or exposure without taking into account the actions that management has taken or might take (e.g., implementing controls)
- 1.2.15. **Materiality** is an auditing concept regarding the importance of an item of information with regard to its impact or effect on the functioning of the entity being audited. An expression of the relative significance or importance of a particular matter in the context of the organization as a whole.
- 1.2.16. **Objectivity** is the ability to exercise judgment, express opinions and present recommendations with impartiality.
- 1.2.17. **Professional competence** is proven level of ability, often linked to qualifications issued by relevant professional bodies and compliance with their codes of practice and standards.
- 1.2.18. **Professional judgement** is the application of relevant knowledge and experience in making informed decisions about the courses of action that are appropriate in the circumstances of the IS audit and assurance engagement.
- 1.2.19. **Reliable information** is information that is accurate, verifiable and from an objective source.
- 1.2.20. **Residual risk** is the remaining risk after management has implemented a risk response.
- 1.2.21. **Risk assessment** is a process used to identify and evaluate risk and its potential effects.
- 1.2.22. **Sufficient evidence** is measure of the quantity of audit evidence; supports all material questions to the audit objective and scope.
- 1.2.23. **Suitable information**: Relevant (i.e., fit for its intended purpose), reliable (i.e., accurate, verifiable and from an objective source) and timely (i.e., produced and used in an appropriate time frame) information.

### 1.3. Objectives

This Risk Based IT Audit Procedure shall help to achieve the following objectives:

- 1.3.1. Establishes standards that address IT auditor roles and responsibilities; knowledge and skills; diligence, conduct and reporting requirements.
- 1.3.2. Defines terms and concepts specific to IT Audit Function.
- 1.3.3. Provides guidance and tools and techniques on the planning, design, conduct and reporting of IT audit activities.



#### **1.4. Scope**

IT Audit Function shall cover all the following but not limited to IT, information system and digital related activities of the Bank like:

- 1.4.1. Evaluates the effectiveness of the Bank's IT strategy, governance framework, plans, policies, procedures, and practices.
- 1.4.2. Assesses compliance with the Bank's policies, procedures, NBE directives, and other applicable regulatory requirements.
- 1.4.3. Evaluates the adequacy and effectiveness of IT risk management, cybersecurity, and internal control frameworks.
- 1.4.4. Assesses the design and operating effectiveness of general IT controls and application controls.
- 1.4.5. Conducts or review annual cyber threat assessments, vulnerability assessments, penetration testing, and other IT audit activities as required by applicable authorities.
- 1.4.6. Identifies control weaknesses, recommend corrective actions, and follow up on the implementation of agreed audit recommendations.
- 1.4.7. Conducts information systems audits to assess the security, reliability, integrity, and effectiveness of information systems and IT infrastructure.
- 1.4.8. Conducts operational IT audits to evaluate the effectiveness, efficiency, and reliability of IT operations and support services.
- 1.4.9. Reviews financial transaction processing systems, information system functionality, and the implementation of key automated controls.
- 1.4.10. Evaluates the performance, availability, reliability, and security of applications, networks, data transmission systems, and IT services.
- 1.4.11. Assesses IT change management processes, technology projects, resource acquisition, and the effectiveness of technology investments.
- 1.4.12. Evaluates vendor management practices, outsourced IT services, and compliance with service level agreements.
- 1.4.13. Assesses business continuity management, disaster recovery capabilities, backup arrangements, and recovery site effectiveness.
- 1.4.14. Evaluates digital transformation initiatives, technology innovations, product development processes, customer data protection measures, and compliance with applicable standards such as PCI-DSS.

- 1.4.15. Assesses the effectiveness of management information systems in supporting decision-making and ensuring the confidentiality, integrity, and availability of information.
- 1.4.16. Participates in advisory capacity in technology projects, system development, and new product initiatives without assuming management responsibilities.
- 1.4.17. Evaluates compliance with laws, regulations, and requirements relating to data privacy, confidentiality, and information security.
- 1.4.18. Assesses the economy, efficiency, effectiveness, and safeguarding of IT resources and assets.
- 1.4.19. Evaluates performance against approved plans, objectives, targets, and key performance indicators.

## **1.5. Governing Rules**

This Guideline operates within the following governing rules:

- 1.5.1. Coop bank's Internal Audit Charter
- 1.5.2. Risk Based Internal Audit Procedure
- 1.5.3. Risk based internal auditing directives No.SBB/76/2020
- 1.5.4. Requirements for IT Management of Banks Directive No.SBB/83/2022
- 1.5.5. Bank corporate governance Directive No.SBB/91/2024
- 1.5.6. ITAF (IT Audit Framework) as issued by ISACA
- 1.5.7. Controls Objectives for Information and Related Technology (COBIT)
- 1.5.8. Global internal audit standards as issued by Institute of Internal Auditors (IIA)

## 1.6. Workflow



## **1.7. Duties and Responsibilities**

### **1.7.1. Board of Directors**

Board of Directors of the Bank shall:

- 1.7.1.1. Approve Internal Audit Charter and Risk Based IT Audit Procedure;
- 1.7.1.2. Ensure that all IT and related processes/teams have prepared risk register; review and approve the same, and ensure that management has dispatched same to internal audit function;
- 1.7.1.3. Establish and ensure effective functioning of audit committees that shall be responsible for overseeing the bank's IT audit activities;
- 1.7.1.4. Approve and ensure periodic review of the IT audit procedures and annual risk based IT audit plan; and

### **1.7.2. Board Audit Sub-Committee**

Board Audit Sub-committee shall:

- 1.7.2.1. Ensure the IT audit function is discharging its responsibilities in an independent manner;
- 1.7.2.2. Review the scope of audit plan, budget of IT audit function, and ensure that coverage of matters of regulatory interests within the audit plan is adequate;
- 1.7.2.3. Review audit reports at least quarterly and ensure that the senior management is taking necessary and timely corrective actions to address control weaknesses and compliance issues;
- 1.7.2.4. Ensure that the IT audit function has adequate resources to carry out its duties that commensurate with the IT audit plan and scope; and

### **1.7.3. Executive Management**

- 1.7.3.1. Provides necessary resources needed for the effective performance of IT audit function;
- 1.7.3.2. Prepares IT risk register that identifies inherent risks and internal control and/or risk mitigations;
- 1.7.3.3. Ensures that the IT audit is fully informed of new developments, products/services, projects and operational changes as well as associated risks;

- 1.7.3.4. Provides full access to required information and explanations to support the audit work and not withhold information from the auditors; and
- 1.7.3.5. Prepares action plan to rectify findings of IT audit and take timely and appropriate actions.

#### **1.7.4. Chief Internal Auditor**

- 1.7.4.1. Develops, obtains approval for, and implements the annual risk-based IT audit procedure and plan.
- 1.7.4.2. Issues quarterly, semi-annual, and annual reports to the Board/Audit Committee and the Chief Executive Officer.
- 1.7.4.3. Undertakes investigations of suspected fraud; reports significant fraud immediately to the Chief Executive Officer and Board/Audit Committee.
- 1.7.4.4. Establishes criteria for selecting, maintaining, and upgrading IT audit staff with sufficient knowledge and skills.

#### **1.7.5. Director of IT Audit**

- 1.7.5.1. Directs IT audit team, monitors overall IT audit activities, and coach IT Audit staff
- 1.7.5.2. Develops risk-based annual IT audit procedure and plan and implements after securing approval;
- 1.7.5.3. Defines the overall audit scope, design audit programs, and supervises activities of assigned audit staff.
- 1.7.5.4. Participates in staff selection or hiring of IT Audit sub-process;
- 1.7.5.5. Communicates the results of audit and consulting engagements via written reports on timely basis;
- 1.7.5.6. Benchmarks best practices of audit work process and promotes continuous process improvement;
- 1.7.5.7. Evaluates the performance of IT auditors and take appropriate corrective action;
- 1.7.5.8. Reviews and approves the audit programs;
- 1.7.5.9. Reviews audit reports and working papers produced by audit teams and provide comments;
- 1.7.5.10. Ensures preparation of complete and comprehensive of various engagements and progress IT audit reports;

- 1.7.5.11. Follows up on implementation of recommendations for IT Audit findings; and
- 1.7.5.12. Performs other activities or assignments as assigned.

#### **1.7.6. Senior Manager IT Audit**

- 1.7.6.1. Prepares operational plans, budgets, and lead the IT audit team.
- 1.7.6.2. Defines the overall audit scope, design audit programs, and oversee assigned audit staff through to the completion of the entire audit.
- 1.7.6.3. Coordinates activities of IT auditors in conducting audit engagements.
- 1.7.6.4. Ensures that auditee responses are received in a timely fashion, are in line with recommendations
- 1.7.6.5. Follows up on implementation of recommendations for IT Audit findings;
- 1.7.6.6. Leads all IT audit activities and methodologies of audit in compliance with Internal Audit charter and Risk Based IT Audit procedure of the Bank;
- 1.7.6.7. Ensures preparation of complete and comprehensive of various engagements and progress IT audit reports;
- 1.7.6.8. Respects and makes others respect the confidentiality of all the identified findings, information, and other business secrets of the Bank;
- 1.7.6.9. Coaches, mentors, and coordinates the subordinate auditors to perform their duties with diligence and strong sense of team spirit;
- 1.7.6.10. Provides key input to the development of the strategic and annual internal audit plan
- 1.7.6.11. Applies and upholds the principles of integrity, objectivity, confidentiality and competency;
- 1.7.6.12. Evaluates the performance of the team members, or IT Auditors under the team; and
- 1.7.6.13. Performs other duties as assigned

#### **1.7.7. Principal IT Auditor**

- 1.7.7.1. Plans and coordinates all activities and performances of engagement audit team;
- 1.7.7.2. Leads all audit activities and methodologies of engagement audit team in compliance with Internal Audit charter and Risk Based Internal Audit procedure of the Bank;
- 1.7.7.3. Plans the objectives, scope and methodology of the audit and prepare an audit program;

- 1.7.7.4. Prepares complete audit reports or leads the preparation process of audit reports;
- 1.7.7.5. Distributes audit activities/tasks to her/his engagement audit team members;
- 1.7.7.6. Respects and make others respect the professional code of conduct of internal auditors;
- 1.7.7.7. Determines the auditing procedures to be used, including sampling methods;
- 1.7.7.8. Performs audit in a professional manner and in accordance with the approved audit program;
- 1.7.7.9. Identifies, develops and documents audit findings and recommendations for improvement using independent judgment concerning areas being reviewed;
- 1.7.7.10. Reviews, on sample basis, sufficiency and accuracy of working papers produced by her/his engagement audit team;
- 1.7.7.11. Prepares and delivers spoken and written presentations to the auditee's during and at the conclusion of the examination, discusses on the findings and recommends corrective actions to improve operations and reduce costs;
- 1.7.7.12. Conducts rectification follow-up;
- 1.7.7.13. Develops checklists for audit engagement; and
- 1.7.7.14. Performs other activities as assigned

#### 1.7.8. **Senior IT Auditor**

- 1.7.8.1. Plans objective, scope and methodology of audit engagements and prepares an audit program;
- 1.7.8.2. Respects and makes other respect the professional code of conduct of internal auditors;
- 1.7.8.3. Performs audit in a professional manner and in accordance with the approved audit program;
- 1.7.8.4. Conducts interviews, surveys, reviews documents, and prepares working papers
- 1.7.8.5. Performs audit, including identifying and defining issues, developing criteria, reviewing, and analysing, evidence, and documenting irregularities;
- 1.7.8.6. Identifies, develops, and documents, audit findings, and recommendations for improvements using independent judgment concerning areas being reviewed;
- 1.7.8.7. Prepares complete and comprehensive audit report;
- 1.7.8.8. Reviews on sample basis sufficiency and accuracy of working papers produced by her/his team members;

- 1.7.8.9. Assists development of checklists for audit engagements;
- 1.7.8.10. Examines and evaluates effectiveness and adequacy of internal control systems;
- 1.7.8.11. Performs evaluation of operational efficiency;
- 1.7.8.12. Performs review on established systems for ensuring codes of conduct, compliance with regulatory and legal requirements, and implementation of procedures and policies;
- 1.7.8.13. Conducts rectification follow-up; and
- 1.7.8.14. Performs other duties as assigned

#### **1.7.9. IT Auditor**

- 1.7.9.1. Plans objectives, scope and methodology of the audit engagements and prepares audit programs in collaboration with Principal/Senior Auditor;
- 1.7.9.2. Respects the professional code of conduct;
- 1.7.9.3. Performs audit in a professional manner and in accordance with the approved audit program;
- 1.7.9.4. Conducts interview, survey, review document, and prepare working papers;
- 1.7.9.5. Performs audit, including identifying and defining issues, developing criteria, reviewing, and analysing, evidence, and documenting irregularities;
- 1.7.9.6. Identifies, develops, and documents audit findings, and recommendations for improvement using independent judgment concerning areas being reviewed;
- 1.7.9.7. Prepares complete and comprehensive audit reports;
- 1.7.9.8. Conducts rectification follow-up;
- 1.7.9.9. Examines and evaluates effectiveness and adequacy of the internal control systems; and
- 1.7.9.10. Performs other duties as assigned



## PART TWO

### 2. Risk Based IT Audit Planning

#### 2.1. Annual IT Audit Planning

As per the IIA (Global Internal Audit Standard 9.4) and NBE directive SBB/76/2020, Internal Audit Process is expected to prepare annual audit plan and quarterly revision. While preparing annual audit plan, Risk Based Audit approach should be employed. Risk-Based Auditing (RBA) is an audit approach that focuses an organization's internal audit resources on the areas of highest risk. Instead of reviewing every process on a rigid, predetermined schedule (traditional auditing), RBA prioritizes audits based on the likelihood and impact of risks that could prevent the organization from achieving its strategic goals.

Risk Based Internal Auditing (RBIA) is a methodology that links internal auditing to the Bank's overall risk management framework.

The basic conceptual framework for preparing risk-based audit planning has the following distinct stages:

Step-1: - Determining and categorizing the audit universe.

Step-2: - Evaluating audit objects

- Select the risk factors
- Identifying sources of information and data;
- Determine the related importance of each risk factor;
- Assign risk level to each factor based on their significance;
- Calculate a risk score for each audit object.

Step-3: - Rank the audit objects based on the risk scored in descending order and determine the frequency of the audit.

Step-4: - Annual audit plan approval

##### 2.1.1 Determining and Categorizing the Audit Universe

2.1.1.1 Audit universe is a comprehensive directory or map of every single auditable entity, process, system, business unit and activities within the Bank that can be subject to internal audit review.

2.1.1.2 The determination of the audit universe will be based on the knowledge of the Bank's strategic plan and its operations, a review of the bank's organizational charts and function and responsibility statements of all work units and discussions with responsible management personnel.

## 2.1.2. Evaluating Audit Objects

### 2.1.2.1. Select the Risk Factors

Given scarcity of audit resources, i.e., human resources and budget, it is important to focus on auditable areas with the highest risk exposure. As a result, this phase of the analysis should be structured to capture both quantitative (size of budget, profitability contribution, operational losses, number of customers...) and qualitative (reputational risk, regulatory sensitivity, strategic importance, management concern...) risk factors that play a key role in the audit selection process. Based on the nature of the Bank's activities, environment in which it operates and its structure, the under listed risk factors are selected for the purpose of the Annual Risk Based IT Audit Planning.

Risk factors identified are:

- i. **Risk Register of Processes/Units:** - Work units' risk register should be considered as one of the rating criteria.
- ii. **Net Residual Risk:** to determine the net residual risk, analyze and assess inherent and control risks; and determine net residual risks so as to prioritize the audit work accordingly.

**Inherent Risk:** the risk of material misstatement, non-compliance in the absence of controls. Consider factors like complexity of system/process, economic and regulatory environment, errors or exposure to fraud and external shocks.

**Control Risk:** the risk that internal control will fail to prevent, detect or correct material misstatement or error. Consider factors design and implementation of controls, frequency of control failures and prior control test result.

**Residual Risk:** the remaining risk after considering effectiveness of internal control.

The following key steps shall be followed while evaluating audit object.

Step 1: Identify key risks - Operational Risk, Compliance Risk, IT Risk

Step 2: Assess inherent risks - likelihood of occurrence, potential impact and rate as low medium or high.

Step 3: Assess control risks - effectiveness of controls, frequency of failure and rate as low medium or high.

Step 4: Compute residual risk - Residual Risk = Inherent Risk - Control Risk. Then rate as low medium or high.

Step 5: Prioritize audit objects based on rating

- High residual risk requires immediate attention and extensive testing;
- Medium residual risk requires periodic review and moderate testing; and
- Low residual risk requires limited testing and reliance on controls.

**Template for assessing inherent and control, to determine net residual risk, is annexed**

| Risk Area                          | Inherent Risk | Control Risk | Residual Risk | Audit Priority | Rationale                                                             |
|------------------------------------|---------------|--------------|---------------|----------------|-----------------------------------------------------------------------|
| Cybersecurity Risk                 | High          | Medium       | Medium        | High           |                                                                       |
| Application & Digital Banking Risk | High          | Medium       | High          | High           |                                                                       |
| Data Governance & Privacy Risk     | High          | Medium       | High          | High           |                                                                       |
| Operational Risk                   | Medium        | Medium       | Medium        | Medium         | Moderate risk of fraud and errors; controls are moderately effective. |
| Compliance Risk                    | High          | High         | High          | High           | Frequent regulatory changes; controls are ineffective.                |
| Political/Economic Risk            | High          | Medium       | Medium        | High           | Exposure to political instability; controls are moderately effective. |

Table 1: Template for assessing inherent control, to determine net residual risk

- iii. **Prior Audit Results:** - significant adverse findings in a prior audit increases audit interest. While evaluating this key variable, the following factors should be considered; prior audit findings, time since last audit, attempted theft & fraud and resolution of previous findings.
- iv. **Fraud Potential Activities:** -Some activities and functions are more prone to fraud and corruption. These are processes, systems, or transactions that present a higher likelihood of intentional misuse, manipulation, unauthorized access, or financial and operational fraud. Examples : User access management and privileged accounts, Payment processing and fund transfers, Vendor creation and master data changes,

Procurement and contract management, System parameter and configuration changes.

- v. **Confidence in Management:** - Confidence in Management is the level of trust placed in management's ability, Integrity and willingness to effectively govern operations, manage risks, maintain internal controls, ensure compliance, and achieve organizational objectives. Given the integrity and ethical values of the Management; qualified and experienced managers usually solve problems more efficiently and achieve better results and could weigh the level of risk they take. In contrast, work units that are managed by less experienced and less qualified managers may be exposed to a higher risk.
- vi. **Recent Change since last audit plan:** - Change, i.e. in terms of organizational, operational, economical and key personnel is known to generate increased risk. For example; high turnover of staffs is likely to reduce the effectiveness of controls as staff is less experienced; reorganization of functions can also generate uncertainty for staffs which limits their effectiveness
- vii. **Performance:** - Unable to perform to the level expected could be the threat to the Bank's going concern and could attract the attention of the audit. Example system availability, digital banking activities, ...
- viii. **Reputational Sensitivity:** - the prospect of significant adverse notoriety, as a consequence of either acts of noncompliance and low service quality, serves to increase audit interest. When evaluating this key variable, the following factors needs to be considered: compliance with laws and regulation.
- ix. **Key Stakeholders' Interest/Demand:** - Given the assurance is provided to key stakeholders, their area of interest should be considering while evaluating audit universes. However, regulatory requirement audits should be carried out prior from the rest and man-hours allocated accordingly.
- x. **Investment and Running Cost:** - Initial investment, vendor, cost of compliance, cost related to technology obsolescence and licensing cost shall be considered.
- xi. **Cyber-security Threats:** Risks include data breaches, malware, phishing, ransomware, and hacking attempts that could compromise customer information and financial data.

- xii. **IT System Reliability and Availability:** Risks associated with system downtime or failure of core banking systems, payment gateways, or online banking platforms, which could disrupt services and lead to financial losses or customer dissatisfaction.
- xiii. **System Change Management:** Risks from poor management of changes to IT systems, including software updates, hardware changes, or system migrations, which could result in unplanned outages or system failures.
- xiv. **Third-Party Risks:** Given third-party services like cloud services, software, or security solutions are out of the Bank's control, same should be considered as one of the rating criteria with the consideration of security vulnerabilities and service disruptions, that could affect the bank's operations.
- xv. **Disaster Recovery and Business Continuity:** Existence of disaster recovery plans to restore critical services after a major disruption, impacting the Bank's ability to operate smoothly.
- xvi. **Access Controls and Authorization:** Custodians of controls over user access to systems and data, is considered one of the evaluation criteria due to the associated risk like unauthorized access or fraud.
- xvii. **IT Governance and Oversight:** Weak governance frameworks that fail to monitor and enforce IT policies and procedures can expose the bank to operational and regulatory risks.
- xviii. **System complexity (System Integration and Interoperability):** Complex, highly customized, and legacy systems generally carry higher technology and control risks and should receive greater audit attention. These are risks related to complexity and integration issues between different IT systems, which could cause data inconsistencies or processing errors.

#### 2.1.3. Source of Information

The required information for the risk assessment process could be found from a variety of sources. Such sources include: a. Key Stakeholder input;

- i. Brainstorming through workshop;
- ii. Consideration of applicable laws, regulations, policies and procedures;
- iii. External source;

- iv. Prior audit reports including the Bank's External Auditors and National Bank of Ethiopia Examiner reports;
- v. The Bank's operational performance data;
- vi. The Bank's human resource records;
- vii. The Bank's risk register and fraud related data;
- viii. IT related Benchmarks and Standards; and Others

#### 2.1.4. **Determine the Related Importance of Each Risk Factor**

While the key risk factors considered in the first step are assumed to be general indicators of risk exposure, the key factors cannot be assumed to be of equal significance in evaluating every prospective audit object. Therefore, the second step of the extended analysis is the assignment of a significance weight to each risk factor with a consideration of the underlining impacts: -

- i. Financial impact: - the monetary consequences for the Bank if the risk occurs.
- ii. Impact on reputation: - the consequences with regard to the reputation of the Bank.
- iii. Regulatory impact: - the occurrence of the risk may result in penalty and other sanctions.
- iv. Impact on strategic objectives, pillars and initiatives: - the extent to which the strategy of the Bank may be impacted by the occurrence of the risk.
- v. Impact on People: - unplanned loss of key people and skills can significantly impact the Bank.
- vi. Cybersecurity Threats: - refers to the potential risks and vulnerabilities related to information security within the bank. This encompasses any threat that could compromise the confidentiality, integrity, or availability of the organization's digital assets, systems, and data.

### 2.1.5. Determining Weight and Level of each Risk Factor

i. The under Listed Risk Weights are given to each Risk

| % Weight                                                                          |                                 |                         |
|-----------------------------------------------------------------------------------|---------------------------------|-------------------------|
|                                                                                   | Given Risk Weight               | Computed Risk Weight    |
| Risk Factors                                                                      | (a)                             | Weight for Risk Factor) |
| <b>1. Risk Register of Work</b>                                                   | Assigned Risk Factor Weight 5%  |                         |
| 1.1 Number of High Risks                                                          | 70%                             | 3.50%                   |
| 1.2 Contribution to the total risk registered                                     | 30%                             | 1.50%                   |
| <b>Sub-total</b>                                                                  | <b>100%</b>                     | <b>5%</b>               |
| <b>2. Net Residual Risk</b>                                                       | Assigned Risk Factor Weight 10% |                         |
| 2.1. Credit Risk                                                                  | 30%                             | 3.00%                   |
| 2.3 Operational Risk                                                              | 30%                             | 3.00%                   |
| 2.4 Compliance Risk                                                               | 40%                             | 4.00%                   |
| <b>Sub-total</b>                                                                  | <b>100%</b>                     | <b>10%</b>              |
| <b>3. Prior Audit Results</b>                                                     | Assigned Risk Factor Weight 10% |                         |
| 3.1 Audit findings including NBE and external audit (Number, occurrence & amount) | 50%                             | 5.00%                   |
| 3.2 Time elapsed since last Audit                                                 | 20%                             | 2.00%                   |
| 3.3 Un-rectified reported findings in terms of occurrence in previous audit       | 30%                             | 3.00%                   |
| <b>Sub-total</b>                                                                  | <b>100%</b>                     | <b>10%</b>              |
| <b>4. Fraud Potential Activities</b>                                              | Assigned Risk Factor Weight 5%  |                         |
| 4.1 Vendor onboarding and management                                              | 30%                             | 1.50%                   |
| 4.2 Procurement and maintenance                                                   | 40%                             | 2.00%                   |
| 4.3 Master data changes                                                           | 30%                             | 1.50%                   |
| <b>Sub-total</b>                                                                  | <b>100%</b>                     | <b>5.00%</b>            |
| <b>5. Confidence in Management</b>                                                | Assigned Risk Factor Weight 5%  |                         |
| 5.1 Qualification                                                                 | 20%                             | 1.0%                    |
| 5.2 Experience                                                                    | 30%                             | 1.5%                    |
| 5.3 Performance evaluation                                                        | 30%                             | 1.5%                    |
| 5.4 Integrity and ethical values                                                  | 20%                             | 1.0%                    |
| <b>Sub-total</b>                                                                  | <b>100%</b>                     | <b>5%</b>               |
| <b>6. Recent Change since last audit plan</b>                                     | Assigned Risk Factor Weight 5%  |                         |
| 6.1 Reorganization of functions                                                   | 30.0%                           | 1.5%                    |
| 6.2 Change of leadership/key managers                                             | 70.0%                           | 3.50%                   |
| <b>Sub-total</b>                                                                  | <b>100%</b>                     | <b>5%</b>               |
| <b>7. Performance</b>                                                             | Assigned Risk Factor Weight 5%  |                         |
| 7.1 Operational Performance                                                       | 40%                             | 2.00%                   |

|                                                                                         |                                 |               |
|-----------------------------------------------------------------------------------------|---------------------------------|---------------|
| 7.2 Controllable expense                                                                | 40%                             | 2.00%         |
| 7.3 Economic benefit from the work unit's                                               | 20%                             | 1.00%         |
| <b>Sub-total</b>                                                                        | <b>100%</b>                     | <b>5.00%</b>  |
| <b>8. Reputational Sensitivity</b>                                                      | Assigned Risk Factor Weight 5%  |               |
| 8.1 Customer's complains (regarding service efficiency, corruption, fraud etc.)         | 30%                             | 1.50%         |
| 8.2 Breach of regulatory/statutory / requirement                                        | 70%                             | 3.50%         |
| <b>Sub-total</b>                                                                        | <b>100%</b>                     | <b>5.00%</b>  |
| <b>9. Key Stakeholders' Interest/Demand</b>                                             | Assigned Risk Factor Weight 5%  |               |
| 9.1 Key stakeholders (NBE, Board, CEO and Chiefs)                                       | 100%                            | 5.0%          |
| <b>Sub-total</b>                                                                        | <b>100%</b>                     | <b>5.0%</b>   |
| <b>10. Internal and External Environmental Factors</b>                                  | Assigned Risk Factor Weight 5%  |               |
| 10.1 Number of critical incidents report                                                | 100%                            | 5%            |
| <b>Sub-total</b>                                                                        | <b>100%</b>                     | <b>5%</b>     |
| <b>11. Information and Technology</b>                                                   | Assigned Risk Factor Weight 40% |               |
| 11.1 Investment and Running Cost                                                        | 15%                             | 6.00%         |
| 11.2 Cybersecurity Threats (Number of actual and attempts)                              | 10%                             | 4.00%         |
| 11.3 IT System Reliability and Availability number incidents report                     | 10%                             | 4.00%         |
| 11.4 System Change Management (number of changes/upgrade)                               | 5%                              | 2.00%         |
| 11.5 Dependency on third-Party                                                          | 10%                             | 4.00%         |
| 11.6 Disaster Recovery and Business Continuity                                          | 15%                             | 6.00%         |
| 11.7 Access Controls and Authorization (Appropriateness Of custodians)                  | 10%                             | 4.00%         |
| 11.8 IT Governance and Oversight existence                                              | 5%                              | 2.00%         |
| 11.9 System complexity -System Integration and Interoperability (Number of integration) | 20%                             | 8.00%         |
| <b>Sub-total</b>                                                                        | <b>100%</b>                     | <b>40.00%</b> |
| <b>Grand-total</b>                                                                      | <b>100%</b>                     |               |

Table 2: Weights Assigned for each Risk Sub-Factors - Annual Plan



## ii. Risk Level to each Factors based on their Significance

| Risk Factors                                                                      | Parameters                                                                                                           | Risk level                                    |            |                   |
|-----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|-----------------------------------------------|------------|-------------------|
|                                                                                   |                                                                                                                      | 3                                             | 2          | 1                 |
| 1. Risk Register of Work                                                          |                                                                                                                      |                                               |            |                   |
| 1.1 Number of High Risks                                                          | Number of registered risks with "high" risk.                                                                         | ≥ 4                                           | 2 to 3     | 1                 |
| 1.2 Contribution to the total risk registered                                     | %age contribution to the total risk registered.                                                                      | >1                                            | 0.5 to 1   | <0.5              |
| 2. Net Residual Risk                                                              |                                                                                                                      |                                               |            |                   |
| 2.1. Credit Risk                                                                  | • Likelihood of risk occurrence post-control implementation.                                                         | High                                          | Medium     | low               |
| 2.3 Operational Risk                                                              |                                                                                                                      | High                                          | Medium     | low               |
| 2.4 Compliance Risk                                                               | • Potential impact of the risk if it materializes.                                                                   | High                                          | Medium     | low               |
| 3. Prior Audit Result                                                             |                                                                                                                      |                                               |            |                   |
| 3.1 Audit findings including NBE and external audit (Number, occurrence & amount) | Number of major findings reported                                                                                    | ≥7                                            | 3 to 6     | <3                |
| 3.2 Time elapsed since last Audit                                                 | Number of days                                                                                                       | >365                                          | 180 to 365 | <180              |
| 3.3 Un-rectified reported findings in terms of occurrence in previous audit       | Number of unrectified findings                                                                                       | >5                                            | 3 to 5     | <3                |
| 4. Fraud Potential Activities                                                     |                                                                                                                      |                                               |            |                   |
| 4.1 Vendor onboarding and management                                              | Approval Compliance (likelihood of creation or modification bypassing established approval workflows)                | High                                          | Medium     | low               |
| 4.2 Procurement and maintenance                                                   | Approval Compliance (likelihood of purchases without required approvals or beyond delegated authority limits.)       | High                                          | Medium     | low               |
| 4.3 Master data changes                                                           | Sensitive Data Changes (Frequent changes to bank accounts, payment details, customer information, or vendor records) | High                                          | Medium     | low               |
| 5. Confidence in Management                                                       |                                                                                                                      |                                               |            |                   |
| 5.1 Qualification                                                                 | Level of education                                                                                                   | Diploma plus related professional certificate | Degree     | Masters and above |
| 5.2 Experience                                                                    | Year of service                                                                                                      | ≤5                                            | >5≤10      | >10               |
| 5.3 Performance evaluation                                                        | last two semi annuals average appraisals                                                                             | <50                                           | >50<80     | ≥80               |

|                                                                                     |                                                                 |                                     |                                       |                                  |
|-------------------------------------------------------------------------------------|-----------------------------------------------------------------|-------------------------------------|---------------------------------------|----------------------------------|
| 5.4 Integrity and ethical values                                                    | Degree of reprimand                                             | Penalty of %age of basic salary     | Written warnings                      | No warning                       |
| 6. Recent Change since last audit plan                                              |                                                                 |                                     |                                       |                                  |
| 6.1 Reorganization of functions                                                     | work unit specific where the change occurred                    | Processes and Branches              | Districts                             |                                  |
| 6.2 Change of leadership/key managers                                               |                                                                 |                                     |                                       |                                  |
| 7. Performance                                                                      |                                                                 |                                     |                                       |                                  |
| 7.1 Operational Performance                                                         | Rate of target achievement                                      | ≤50%                                | 50 to 79%                             | ≥80%                             |
| 7.2 Controllable expense                                                            | % of adverse variance from own budget                           | ≥10%                                | 1<10%                                 | <1%                              |
| 7.3 Economic benefit from the work unit's                                           | % of expected income from digital products                      | ≤50%                                | 50 to 79%                             | ≥80%                             |
| 8. Reputational Sensitivity                                                         |                                                                 |                                     |                                       |                                  |
| 8.1 Customer's complains (regarding service efficiency, corruption, fraud and etc.) | number of reported external complains since previous audit      | >5                                  | 3≤5                                   | <2                               |
| 8.2 Breach of regulatory/statutory / requirement                                    | number of reported noncompliance and fines since previous audit | ≥3                                  | 2 to 3                                | <2                               |
| 9. Key Stakeholders' Interest/ Demand                                               |                                                                 |                                     |                                       |                                  |
| 9.1 Key stakeholders (NBE, Board, CEO and Chiefs)                                   | Specific demand/request of stakeholders for audit service       | NBE, Board and Executive Management | Districts, Sub-processes and Branches |                                  |
| 10. Internal and External Environmental Factors                                     |                                                                 |                                     |                                       |                                  |
| 10.1 Number of critical incidents report                                            | Number of Occurrence                                            | ≥3                                  | 2 to 3                                | 1                                |
| 11. Information and Technology                                                      |                                                                 |                                     |                                       |                                  |
| 11.1 Investment and Running Cost (innovations and developments)                     | Total Investment and running cost                               | >100 Mill                           | 50 Mill to 100 Mill                   | <50 Mill                         |
| 11.2 Cybersecurity Threats (Number of actual and attempts)                          | Number of incidents                                             | ≥5                                  | 2 to 4                                | <2                               |
| 11.3 IT System Reliability and Availability number incidents report                 | System uptime                                                   | Uptime <95%                         | 95 to 99 %                            | >99%                             |
| 11.4 System Change Management (number of changes/upgrade)                           | Number of changes/upgrades                                      | >10 high impact changes per year    | 4 to 10 high impact changes per year  | ≤ 3 high impact changes per year |
| 11.5 Dependency on third-Party                                                      | Number of services provided by vendor                           | ≥ 7 critical services               | 3 to 6 critical services              | <3 critical services             |

|                                                                                         |                                              |                                        |                                                         |                                     |
|-----------------------------------------------------------------------------------------|----------------------------------------------|----------------------------------------|---------------------------------------------------------|-------------------------------------|
| 11.6 Disaster Recovery and Business Continuity plans                                    | Existence of plans                           | No DR/BC plans, no testing,            | DR/BC plans exist but are outdated or partially tested, | DR/BC plans exist, tested annually. |
| 11.7 Access Controls and Authorization (Appropriateness Of custodians)                  | Number of users                              | >10 users                              | 4 to 10 users                                           | <4 users                            |
| 11.8 IT Governance and Oversight existence                                              | Existence of governance framework            | No formal governance framework exists. | Not updated 5 years                                     | Not updated 3-<5 years              |
| 11.9 System complexity -System Integration and Interoperability (Number of integration) | System complexity and number of integrations | >5 integrations                        | 3 to 5 integrations                                     | <3 integrations                     |

Table 3: Assign Risk Level to each Factors based on their Significance -Annual plan

#### 2.1.6. Calculate a Risk Score for Each Audit Object

In order to calculate 'the risk score of each Audit object, computing of a Risk Evaluation Factor (REF) is required. The REF for all audit objects provides a means of systematically selecting auditable work units to maximize audit effectiveness in the annual planning process to develop the audit plan. Basing the above steps the following table is developed using a given scenario for the purpose of clarification.

| Risk Factors                                                                      | Parameters                                                                                                             | Step-1<br>Sample Data       |       |       | Step-2<br>Assignment of<br>Risk Level<br>(Refer Tabet 2)<br>a |           |       | Comput<br>e d Risk<br>Weight<br>(Refer<br>table 1)<br>b | Step-3<br>Computed Risk<br>Evaluation Factor<br>(c=a*b) |       |       |
|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|-----------------------------|-------|-------|---------------------------------------------------------------|-----------|-------|---------------------------------------------------------|---------------------------------------------------------|-------|-------|
|                                                                                   |                                                                                                                        | Audit Objects/Work<br>Units |       |       | Audit<br>Objects/Work<br>Units                                |           |       |                                                         | Audit Objects/Work<br>Units                             |       |       |
|                                                                                   |                                                                                                                        | obj.1                       | obj.2 | obj.3 | obj<br>.1                                                     | obj<br>.2 | obj.3 |                                                         | obj.1                                                   | obj.2 | obj.3 |
|                                                                                   |                                                                                                                        |                             |       |       |                                                               |           |       |                                                         |                                                         |       |       |
| 1. Risk Register of Work                                                          |                                                                                                                        |                             |       |       |                                                               |           |       |                                                         |                                                         |       |       |
| 1.1 Number of High Risks                                                          | Number of registered risks with "high" risk.                                                                           | 3                           | 1     | 7     | 2                                                             | 1         | 3     | 3.50%                                                   | 0.07                                                    | 0.04  | 0.11  |
| 1.2 Contribution to the total risk registered                                     | %age contribution to the total risk registered.                                                                        | 0.7                         | 0.2   | 1.5   | 2                                                             | 1         | 3     | 1.50%                                                   | 0.03                                                    | 0.02  | 0.05  |
| 2. Net Residual Risk                                                              |                                                                                                                        |                             |       |       |                                                               |           |       |                                                         |                                                         |       |       |
| 2.1. Credit Risk                                                                  | • Likelihood of risk occurrence post-control implementation.<br><br>• Potential impact of the risk if it materializes. | M                           | H     | L     | 2                                                             | 3         | 1     | 3.00%                                                   | 0.06                                                    | 0.09  | 0.03  |
| 2.3 Operational Risk                                                              |                                                                                                                        | H                           | L     | M     | 3                                                             | 1         | 2     | 3.00%                                                   | 0.09                                                    | 0.03  | 0.06  |
| 2.4 Compliance Risk                                                               |                                                                                                                        | L                           | M     | H     | 1                                                             | 2         | 3     | 4.00%                                                   | 0.04                                                    | 0.08  | 0.12  |
| 3. Prior Audit Results                                                            |                                                                                                                        |                             |       |       |                                                               |           |       |                                                         |                                                         |       |       |
| 3.1 Audit findings including NBE and external audit (Number, occurrence & amount) | Number of major findings reported                                                                                      | 10                          | 4     | 2     | 3                                                             | 2         | 1     | 5.00%                                                   | 0.15                                                    | 0.1   | 0.05  |
| 3.2 Time elapsed since last Audit                                                 | Number of days                                                                                                         | 130                         | 200   | 400   | 1                                                             | 2         | 3     | 2.00%                                                   | 0.02                                                    | 0.04  | 0.06  |
| 3.3 Un-rectified reported findings in terms of occurrence in previous audit       | Number of unrectified findings                                                                                         | 2                           | 6     | 4     | 1                                                             | 3         | 2     | 3.00%                                                   | 0.03                                                    | 0.09  | 0.06  |
| 4. Fraud Potential Activities                                                     |                                                                                                                        |                             |       |       |                                                               |           |       |                                                         |                                                         |       |       |
| 4.1 Vendor onboarding and management                                              | Approval Compliance (likelihood of creation or modification bypassing established approval workflows)                  | L                           | H     | M     | 1                                                             | 3         | 2     | 1.50%                                                   | 0.015                                                   | 0.05  | 0.03  |
| 4.2 Procurement and maintenance                                                   | Approval Compliance (likelihood of purchases without required approvals or beyond                                      | H                           | L     | M     | 3                                                             | 1         | 2     | 2.00%                                                   | 0.06                                                    | 0.02  | 0.04  |

|                                                                                     |                                                                                                                         |               |                     |                                          |   |   |   |       |       |      |      |
|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|---------------|---------------------|------------------------------------------|---|---|---|-------|-------|------|------|
|                                                                                     | delegated authority limits.)                                                                                            |               |                     |                                          |   |   |   |       |       |      |      |
| 4.3 Master data changes                                                             | Sensitive Data Changes<br>(Frequent changes to bank accounts, payment details, customer information, or vendor records) | M             | H                   | L                                        | 2 | 3 | 1 | 1.50% | 0.03  | 0.05 | 0.02 |
| 5. Confidence in Management                                                         |                                                                                                                         |               |                     |                                          |   |   |   |       |       |      |      |
| 5.1 Qualification                                                                   | Level of education                                                                                                      | Master<br>s   | Degre<br>e          | Master<br>s                              |   |   |   | 1.00% | 0     | 0    | 0    |
| 5.2 Experience                                                                      | Year of service                                                                                                         | 7             | 10                  | 5                                        | 2 | 1 | 3 | 1.50% | 0.03  | 0.02 | 0.05 |
| 5.3 Performance evaluation                                                          | last two semi annuals<br>average appraisals                                                                             | 90            | 70                  | 45                                       | 1 | 2 | 3 | 1.50% | 0.015 | 0.03 | 0.05 |
| 5.4 Integrity and ethical values                                                    | Degree of reprimand                                                                                                     | No<br>warning | Written<br>wargings | Penalty<br>of %age<br>of basic<br>salary | 1 | 2 | 3 | 1.00% | 0.01  | 0.02 | 0.03 |
| 6. Recent Change since last audit plan                                              |                                                                                                                         |               |                     |                                          |   |   |   |       |       |      |      |
| 6.1 Reorganization of functions                                                     | work unit specific<br>where the change<br>occurred                                                                      | Proce<br>ss   | Proce<br>ss         | Proces<br>s                              | 3 | 3 | 3 | 1.50% | 0.05  | 0.05 | 0.05 |
| 6.2 Change of leadership/key managers                                               |                                                                                                                         | Proce<br>ss   | Proce<br>ss         | Proces<br>s                              | 3 | 3 | 3 | 3.50% | 0.11  | 0.11 | 0.11 |
| 7. Performance                                                                      |                                                                                                                         |               |                     |                                          |   |   |   |       |       |      |      |
| 7.1 Operational Performance                                                         | Rate of target achievement                                                                                              | 80            | 45                  | 75                                       | 1 | 3 | 2 | 2.00% | 0.02  | 0.06 | 0.04 |
| 7.2 Controllable expense                                                            | % of adverse variance from own budget                                                                                   | 7             | 13                  | 0.5                                      | 2 | 3 | 1 | 2.00% | 0.04  | 0.06 | 0.02 |
| 7.3 Economic benefit from the work unit's                                           | % of expected income from digital products                                                                              | 62            | 90                  | 45                                       | 2 | 1 | 3 | 1.00% | 0.02  | 0.01 | 0.03 |
| 8. Reputational Sensitivity                                                         |                                                                                                                         |               |                     |                                          |   |   |   |       |       |      |      |
| 8.1 Customer's complains (regarding service efficiency, corruption, fraud and etc.) | number of reported external complains since previous audit                                                              | 6             | 1                   | 4                                        | 3 | 1 | 2 | 1.50% | 0.05  | 0.02 | 0.03 |
| 8.2 Breach of regulatory/statutory / requirement                                    | number of reported noncompliance and fines since previous audit                                                         | 2             | 1                   | 1                                        | 2 | 1 | 1 | 3.50% | 0.07  | 0.04 | 0.04 |
| 9. Key Stakeholders' Interest /Demand                                               |                                                                                                                         |               |                     |                                          |   |   |   |       |       |      |      |
| 9.1 Key stakeholders (NBE, Board, CEO and Chiefs)                                   | Specific demand/request of                                                                                              | NBE           | Sub-<br>proces<br>s | Executi<br>ve                            | 3 | 2 | 3 | 5.00% | 0.15  | 0.1  | 0.15 |

|                                                                                          | stakeholders for audit service               |                             |                                       | Manag<br>ement                        |   |   |   |             |             |             |             |
|------------------------------------------------------------------------------------------|----------------------------------------------|-----------------------------|---------------------------------------|---------------------------------------|---|---|---|-------------|-------------|-------------|-------------|
| 10. Internal and External Environmental Factors                                          |                                              |                             |                                       |                                       |   |   |   |             |             |             |             |
| 10.1 Number of critical incidents report                                                 | Number of Occurrence                         | 2                           | 5                                     | 1                                     | 2 | 3 | 1 | 5.00%       | 0.1         | 0.15        | 0.05        |
| 11. Information and Technology                                                           |                                              |                             |                                       |                                       |   |   |   |             |             |             |             |
| 11.1 Investment and Running Cost (innovations and developments)                          | Total Investment and running cost            | 75 mill                     | 500 mill                              | 40 mill                               | 2 | 3 | 1 | 6.00%       | 0.12        | 0.18        | 0.06        |
| 11.2 Cybersecurity Threats (Number of actual and attempts)                               | Number of incidents                          | 3                           | 1                                     | 7                                     | 2 | 1 | 3 | 4.00%       | 0.08        | 0.04        | 0.12        |
| 11.3 IT System Reliability and Availability number incidents report                      | System uptime                                | 96%                         | 99.50 %                               | 90%                                   | 2 | 1 | 3 | 4.00%       | 0.08        | 0.04        | 0.12        |
| 11.4 System Change Management (number of changes/upgrade)                                | Number of changes/upgrades                   | 12                          | 2                                     | 5                                     | 3 | 1 | 2 | 2.00%       | 0.06        | 0.02        | 0.04        |
| 11.5 Dependency on third-Party                                                           | Number of services provided by vendor        | 2                           | 8                                     | 5                                     | 1 | 3 | 2 | 4.00%       | 0.04        | 0.12        | 0.08        |
| 11.6 Disaster Recovery and Business Continuity plans                                     | Existence of plans                           | No DR/BC plans, no testing, | DR/BC plans exist but are outdated    | No DR/BC plans, no testing,           | 3 | 2 | 3 | 6.00%       | 0.18        | 0.12        | 0.18        |
| 11.7 Access Controls and Authorization (Appropriateness Of custodians)                   | Number of users                              | 8                           | 15                                    | 3                                     | 2 | 3 | 1 | 4.00%       | 0.08        | 0.12        | 0.04        |
| 11.8 IT Governance and Oversight existence                                               | Existence of governance framework            | Not updated 5 years         | No formal governance framework exist. | No formal governance framework exist. | 2 | 3 | 3 | 2.00%       | 0.04        | 0.06        | 0.06        |
| 11.9 System complexity - System Integration and Interoperability (Number of integration) | System complexity and number of integrations | 2                           | 7                                     | 4                                     | 1 | 3 | 2 | 8.00%       | 0.08        | 0.24        | 0.16        |
| <b>Total</b>                                                                             |                                              |                             |                                       |                                       |   |   |   | <b>100%</b> | <b>2.01</b> | <b>2.18</b> | <b>2.10</b> |

Table 4: Practical example of how to evaluate audit objects for Branch Audit Sub-process- Annual Plan

### 2.1.7. Schedule Audit

As per the NBE directive, any work units/function /process shall be visited by scheduled audit at least every three years, hence, the first priority should be given for those work units not audited for the last three years. In addition, based on the available man-hours, the remaining work units will be given priority based on the REF. The Audit coverage and the frequency will be conducted as tabulated below.

| Risk Rating | Period within which audit can be scheduled |
|-------------|--------------------------------------------|
| High        | One year                                   |
| Moderate    | Two year                                   |
| Low         | Three year                                 |

### 2.1.8. Annual Audit Plan Approval

- 2.1.8.1. The annual audit plan shall be the final document that contains list of audit objects, specific audit engagement schedule, resource needed and audit performance period. The Major tasks shall be developed taking in to account the available resources of the office, the regulatory requirement, the results of the above annual risk assessment, the incidental activities such as consulting and investigation tasks during the upcoming fiscal year.
- 2.1.8.2. The Chief Internal Auditor shall present annual audit plan to Board Audit Committee and secure approval.
- 2.1.8.4. The Annual Audit plan shall be updated on a quarterly basis by considering changes in the business environment, activities, work processes, and other.

## 2.2. Engagement Planning.

The audit engagement shall begin with an agreement to perform an audit and ends with the delivery of an audit report. It involves assignment of audit team, planning, execution, and reporting to achieve specific audit objectives and provide valuable insights into the subject being audited. The following major steps shall be followed

### **2.2.1. Objectives**

- 2.2.1.1. The IT Auditor should define the audit engagement objectives and document them in the audit engagement plan, which confirms the IT Auditors understanding of the Bank's goals, operations, and challenges.
- 2.2.1.2. Documentation of the audit engagement objectives ensures that testing lends assurance that controls are in place and operating effectively.
- 2.2.1.3. The IT Auditor should develop an audit engagement plan that takes into consideration the objectives of the audit engagement. These objectives might influence the audit engagement, e.g., resources, timeline and deliverables.

### **2.2.2. Scope and Business Knowledge**

- 2.2.2.1. IT Auditors should establish the scope of the audit work based on the audit objectives. And they should plan their work in a manner appropriate for meeting the audit objectives.
- 2.2.2.2. The scope statement of the audit should clearly describe the areas, processes, activities, or systems within the audit entity that will be the subject of the engagement and to which the conclusions will apply. If there are numerical or geographic limitations to the scope of the engagement, these should be specified, e.g. "Tests will be conducted on a random sample of transaction files at each of a representative sample of ten branches."
- 2.2.2.3. The scope may be expressed in terms of the focus of the engagement, e.g. compliance, internal controls, governance processes, information, and risk management.
- 2.2.2.4. The scope should describe the time period covered by the audit, for example, the period or fiscal year during which files or transactions to be examined were originally prepared.
- 2.2.2.5. The audit scope should also describe any areas, processes, activities, or systems that might normally be associated with the audit entity but are excluded.
- 2.2.2.6. It should be evident in the scope how conducting the engagement as stated will lead to the formulation of conclusions appropriate to the engagement objectives.
- 2.2.2.7. As part of the planning process, IT Auditors should obtain an understanding of the Bank's and its processes. This will assist them in determining the significance of the areas being reviewed as they relate to the objectives of the Bank.



- 2.2.2.8. As part of a preliminary assessment, IT Auditors should gain an understanding of the types of personnel, events, transactions, and practices that can have a significant effect on the Bank, function, process or data that are the subject of the audit engagement.
- 2.2.2.9. The auditor's knowledge of the Bank should include the business and financial risk facing the Bank, and the extent to which the Bank relies on outsourcing to meet its objectives.
- 2.2.2.10. Auditors should use information obtained as part of preliminary assessment in identifying potential problems, formulating the objectives and scope of the work, performing the work, and considering actions of management for which they should be alert.

### **2.2.3. Risk assessment of Individual Engagements (Preliminary Risk Assessment)**

- 2.2.3.1. The Risk Assessment should be performed in the way it can provide understanding of the organizations and the environment.
- 2.2.3.2. A risk assessment and prioritization of identified risk for the area under review and the Bank IT environment should be carried out to the extent necessary.
- 2.2.3.3. During the planning process, IT Auditors should establish levels of planning materiality such that the audit work will be sufficient to meet the audit objectives and will use audit resources efficiently.
- 2.2.3.4. Before beginning an audit engagement and during the course of the audit, IT Auditors should consider compliance with applicable laws and professional auditing standards.
- 2.2.3.5. Development of Project plan should be based on the preliminary control evaluation.
- 2.2.3.6. When planning an individual engagement, IT Auditor should identify and assess risk relevant to the area under review.
- 2.2.3.7. The risk assessment results should be reflected in the audit engagement objectives.
- 2.2.3.8. During the risk assessment, IT Auditors should consider the following key documents and information that will have to be analyzed:
- i. Results of prior audit engagements, reviews, and findings, working papers and follow-up report's including any remedial activities.
  - ii. The Bank's risk assessment process/result.
  - iii. The likelihood of occurrence of a particular risk.

- iv. The impact of a particular risk (in monetary or other value measures) if it occurs.
- v. Related legislation or regulations;
- vi. Policies, procedures, standards, manuals, and directives;
- vii. Risk register of the business line/ units
- viii. Results of previous audits or reviews by NBE and external auditors;
- ix. Organization charts;
- x. Budgets;
- xi. Operational and financial data and reports;
- xii. Key performance indicators used by the auditee;
- xiii. Planning and performance reports;
- xiv. Exhaustive list of recent incidents (with or without reputation, operational and financial consequences);
- xv. Job descriptions and delegation instruments;
- xvi. Listings of key personnel;
- xvii. Process and system maps or flow charts;
- xviii. Functional documentation of IT application used;
- xix. Management meeting reports or minutes;
- xx. Management control frameworks;
- xxi. Risk assessments;
- xxii. Management studies or reports;
- xxiii. Reviewing of permanent audit files;
- xxiv. Reviewing recent changes in the Bank such as changes in system, key employees, etc.;
- xxv. Reviewing of related documents/literatures.

2.2.3.9. IT Auditors should ensure full understanding of the activities in scope before assessing risk. The Auditors should request comments and suggestions from stakeholders and other appropriate parties.

2.2.3.10. IT Auditors should recognize that the lower the materiality threshold is, the more precise the audit expectations will be, and the greater the audit risk.

2.2.3.11. IT Auditors should consider possible illegal acts that might require a modification of the nature, timing or extent of the existing audit engagement procedures and corresponding documentation necessary to support potential litigation.

### **2.3. Documenting the Audit Engagement Plan and Audit Program**

2.3.1. IT Auditors work papers should include the audit engagement plan.

2.3.2. An audit engagement plan should include in the terms of reference items such as:

- i. Areas to be audited
- ii. Type of work planned
- iii. High-level objectives and scope of the work
- iv. Fact-finding interviews to be conducted
- v. Relevant information to be obtained
- vi. Procedures to verify or validate the information obtained and its use as audit evidence
- vii. General topics, such as:

- a. Resource availability and allocation
- b. Schedule dates
- c. Type of report
- d. Intended audience
- e. Deliverables

viii. Specific topics, such as:

- a. Identification of tools needed for gathering evidence, performing tests and preparing/summarizing information for reporting
- b. Assessment criteria (Bank's policies, procedures or protocols) to be used to evaluate current practices.
- c. Risk assessment documentation
- d. Reporting requirements and distribution
- e. External reports available (information that can be relied upon, if any)

2.3.3. The project plan should include the requirements related to the timeline of the audit engagement. These elements include but are not limited to the period covered and the different completion dates to perform the audit engagement within the agreed-on schedule.

- 2.3.4. IT Auditors should ensure that audit team resources assigned to the audit engagement have the right skills, knowledge and experience to successfully complete the audit engagement.
- 2.3.5. The IT audit Manager should assign the roles and responsibilities that best match the competencies of the IT audit team members.
- 2.3.6. The project plan should list all deliverables that are linked to the audit engagement.

## **2.4. Managing the Audit Engagement**

- 2.4.1. The Senior Manager, IT Audit Team selects/forms audit teams considering their knowledge, skills and other competencies required to perform the work.
- 2.4.2. The Senior Manager shall distribute the plan across quarters and months of the year and assign the engagement to the team formed.
- 2.4.3. The assigned team shall plan the engagement for the given audit and produce the audit program.
- 2.4.4. The Director IT Audit or the Senior Manager IT Audit shall approve the Audit Program before initiating the actual audit.
- 2.4.5. The audit engagement project plan should be updated and changed as necessary (with appropriate approvals by Chief, Internal Auditor) during the course of the audit engagement. If a concern that warrants the auditor's attention should arise once the audit is under way, auditors should determine how to address the concern. Options include but are not limited to expanding the scope of the audit or scheduling a separate assessment.
- 2.4.6. The IT audit management shall immediately inform the auditee of any changes to the scope of the audit, or the schedule based on the newly identified concern.
- 2.4.7. Planning an audit engagement is a continual and iterative process. As a result of unexpected events, changes in conditions or audit evidence obtained, auditors may need to modify the planned nature, timing, and extent of further audit procedures. For example, when a new regulation is released, an assessment may need to be done immediately to determine any possible impact on the Bank in terms of compliance.
- 2.4.8. The audit plan should consider the possibility of unexpected events that imply risk for the Bank. Accordingly, the audit engagement plan should support prioritization of such events within the audit and assurance processes, based on risk.
- 2.4.9. Include in the audit plan assignment-specific issues, such as:

- i. Availability of resources with appropriate knowledge, skills and experience
- ii. Identification of tools needed for gathering evidence, performing tests and preparing/summarizing information for reporting.
- iii. Assessment criteria to be used.
- iv. Reporting requirements and distribution

2.4.10. IT audit engagements should:

- i. Prepare a separate engagement letter for each IT audit and assurance engagement.
- ii. Communicate relevant elements of the audit to the auditee, using an engagement letter or equivalent to further clarify or confirm involvement in specific engagements.

2.4.11. Communicate the plan so that the auditee is fully informed and can provide appropriate access to individuals, documents and other resources when required.

2.4.12. IT Audit sub-process shall inform the auditee in writing interoffice memo or letter, with terms of reference attached.

2.4.13. The auditee is the Process or team directly responsible or accountable for the auditable area/topic.

## **PART THREE**

### **3. Field Work**

#### **3.1. General Overview**

The purpose of the field work (conduct phase) of the audit is to gather sufficient and appropriate audit evidence to reach a conclusion on each of the objectives identified in the planning phase. Fieldwork is regarded as the beginning of the conduct phase and is interpreted as the point at which the audit team is implementing the audit program, usually on site with the auditee.

#### **3.2. Entrance Conference**

An entrance meeting will normally be held on the first day of fieldwork between the IT Auditors and the auditee. Entrance conference meeting includes at least the following components:

- 3.2.1. Introducing the participating audit team members.
- 3.2.2. Describes the unit or system to be reviewed (Objective, scope, and purpose and approach of the audit);
- 3.2.3. Addressing Auditee's concerns.
- 3.2.4. Discussion on the kinds of information needed and the extent of auditee assistance.
- 3.2.5. Discussion on any changes (in staff, systems, operations, etc.).
- 3.2.6. The need for further meetings during the audit and at the end of the audit;
- 3.2.7. Available resources (personnel, facilities, equipment), and other relevant information to the auditor.
- 3.2.8. Request access to relevant documents and records and provide a list of the items the auditor is looking for.
- 3.2.9. Brief description (for example, a copy of the records management policy, security classification procedure, system certification procedure, organizational chart, and prior audit reports);
- 3.2.10. Decide for the audit resources;
- 3.2.11. Agree on attendance of observers and a guide for the audit team; and
- 3.2.12. Request audit team workspace needs with technology services to support the audit workflow.

### **3.3. Audit Testing**

- 3.3.1. Once the initial meeting has been held, the internal auditor carries out the assigned parts of the audit program. As activities are completed, there will normally be ongoing processes of analyzing and evaluating evidence generated by completing portions of the audit program and formulating, discussing, presenting, and refining observations and findings.
- 3.3.2. The purpose of testing is to confirm that the internal control, risk management and governance systems are operating as intended and to obtain audit evidence.
- 3.3.3. To perform testing, the auditors should use or apply specific audit procedures/techniques like observing, questioning, analyzing, verifying, investigating, evaluating, etc. separately or in combination.
- 3.3.4. The information collected on all matters related to the audit objective and scope of work should be sufficient, reliable, relevant and useful to provide a sound basis for engagement conclusions and recommendations.
- 3.3.5. The auditors should check each sample transaction/activity from its very inception/starting to the end of the recording process, and document all the findings identified in the process.

### **3.4. IT Audit Sampling**

In forming an opinion or conclusion, IT Auditors frequently do not examine all the information available, because doing so may be impractical (e.g., requiring too much time for the auditee and IT Auditors to investigate all information). If examination of all the information is impractical, valid conclusions can be reached using audit sampling.

- 3.4.1. When using statistical or non-statistical sampling methods, IT Auditors should design and select an audit sample, perform audit procedures, and evaluate sample results to obtain sufficient and appropriate evidence to form a conclusion.
- 3.4.2. When using sampling methods to draw a conclusion on the entire population, IT Auditors should use statistical sampling.
- 3.4.3. Sampling should not be used in some instances. For example, sampling should not be used for tests of controls if there is no evidence of performance, such as appropriate segregation of duties.

- 3.4.4. When designing the size and structure of an audit sample, IT Auditors should consider the specific IT audit objectives, the audit procedures that are most likely to achieve those objectives, the nature of the population, the nature of the control (e.g., manual or automated), relevant subgroups within the population, and the sampling and selection methods.
- 3.4.5. In addition, when audit sampling is appropriate, consideration should be given to the nature of the evidence sought, possible error conditions and possible root causes.
- 3.4.6. When considering the IT audit objectives while designing the sample, IT auditors should consider the following:
- i. Purpose of the sample.
  - ii. Sampling unit.
  - iii. Population.
  - iv. Sampling risk and sample size.
  - v. Tolerable error.
  - vi. Underlying expected distribution (e.g., Poisson, binomial, normal or exponential);
  - vii. Behavior over time (e.g., seasonality and decrease in performance);
  - viii. Subpopulations or subgroups that occur naturally should be considered for operational relevance.
  - ix. Outliers.
  - x. Small populations of adverse or rare events; and
  - xi. Data from external support tools that are used to confirm or complement the results of sampling.
- 3.4.7. The purpose of the sample can be:
- i. Compliance testing/test of controls: An audit procedure designed to obtain audit evidence on the effectiveness of the controls and their operation during the audit period. Examples of compliance testing of controls for which sampling can be considered include user access rights, program change-control procedures, procedure documentation, program documentation, follow-up exceptions, review of logs and software license audits.
  - ii. Substantive testing/test of details: An audit procedure designed to obtain audit evidence on the completeness, accuracy or existence of activities or transactions during the audit period. Examples of substantive tests for which sampling can be



considered include re-performance of a complex calculation (e.g., interest) on a sample of accounts, a sample of transactions to vouch for supporting documentation, etc.

The population is the entire set of data from which IT Auditors wish to sample to reach a conclusion on the population. Therefore,

- 3.4.8. The population from which the sample is drawn must be appropriate to test the design and operating effectiveness of the controls and be verified as complete for the specific IT audit objective and scope.
- 3.4.9. To assist in the efficient and effective design of the sample, sampling stratification may be appropriate. Stratification is the process of dividing a population into subpopulations with similar characteristics explicitly defined, so that each sampling unit can belong to only one stratum.
- 3.4.10. When determining sample size, IT Auditors should consider the sampling risk, the amount of errors that is acceptable and the extent to which errors are expected.
- 3.4.11. Sampling risk arises from the possibility that auditor's conclusion may be different from the conclusion that is reached if the entire population is subjected to the same audit procedure. The two types of sampling risk are:
  - i. Risk of incorrect acceptance: A material weakness is assessed as unlikely when, in fact, the population is materially misstated.
  - ii. Risk of incorrect rejection: A material weakness is assessed as likely, when, in fact, the population is not materially misstated.
- 3.4.12. Sample size is affected by the level of sampling risk that the IT auditors are willing to accept.
- 3.4.13. Sampling risk should also be considered in relation to the audit risk model and its components:
  - i. Inherent risk,
  - ii. Control risk and
  - iii. Detection risk, as detailed in Information Technology Audit Framework (ITAF) Standard 1201 Risk Assessment in Planning.

This guideline requires that IT Auditors consider subject matter risk, audit risk and related exposure to the Bank when planning audit engagements.

- 3.4.14. Tolerable error is the maximum error in the population that IT Auditors are willing to accept and still conclude that the test objective is achieved.
- 3.4.15. For substantive tests, tolerable error is related to the auditor's judgment about materiality. In compliance tests, tolerable error is the maximum rate of deviation from a prescribed control procedure that IT Auditors are willing to accept.
- 3.4.16. Smaller sample sizes are justified when the population is expected to be error-free. If auditors expect errors to be present in the population, they must examine a larger sample to conclude that the actual error in the population is not greater than the expected tolerable error. When estimating the expected error rate in a population, IT Auditors should consider matters such as:
- i. Error levels identified in previous audits
  - ii. Changes in Bank procedures
  - iii. Evidence available from an evaluation of the system of internal control, results from analytical review procedures and/or results of preliminary tests of the population
- 3.4.17. IT Auditors should consider, if appropriate, the need to involve specialists in the design and analysis of complex sampling approaches such as stratified random samples that must have statistical validity and sampling that are based on established quality control methods.
- 3.4.18. If IT Auditors conclude that sampling does not allow the IT audit objectives to be achieved and a test of the entire population is required, IT Auditors should consider applying continuous assurance, because it allows testing of the entire population in a timely and cost-effective way.
- 3.4.19. IT Auditors should ensure that the population is complete and control the selection of the sample. Auditors should select sample items to ensure that the sample is representative of the population regarding the characteristics being tested.
- 3.4.20. There are five commonly used sampling methods that are categorized as either statistical sampling methods or non-statistical sampling methods:

Statistical sampling methods:

- i. Simple Random Sampling: Ensures that all combinations of sampling units in the population have an equal chance of selection.
- ii. Systematic Sampling: Involves selecting sampling units using a fixed interval between selections, with the first interval having a random start. Examples include

monetary unit sampling or value-weighted selection in which each individual monetary value (e.g., \$1,000) in the population is given an equal chance of selection. The item that includes the monetary unit is selected for examination because the individual monetary unit cannot be examined separately. This method systematically weighs the selection in favor of the larger amounts. Another example is selecting every  $n^{\text{th}}$  sampling unit.

- iii. Stratified Random Sampling: Ensures that all sampling units in each subgroup have a known chance of selection.

3.4.21. IT Auditors should consider using statistical software for calculating standard deviations and other summary statistics for results of statistical sampling.

Non-statistical sampling methods:

- i. Haphazard Sampling: IT Auditors select the sample without following a structured technique, while avoiding any conscious bias or predictability. Analysis of a haphazard sample should not be relied on to form a conclusion on the entire population.
- ii. Judgmental sampling: IT Auditors place a bias on the sample (e.g., all sampling units over a certain value, all sampling units for a specific type of exception, all negative sampling units). A judgmental sample is not statistically based, and results should not be extrapolated over the population, because the sample is unlikely to be representative of the population.

3.4.22. When the expected audit evidence regarding a specific sample unit cannot be obtained, IT Auditors should consider whether they can obtain sufficient and appropriate audit evidence by performing alternative procedures on the item selected, or by selecting and testing a replacement sample unit.

3.4.23. The work papers should include sufficient detail to describe clearly the sampling objective and the sampling process used. The work papers should include:

- i. Purpose of the sample, including the sample unit
- ii. Source of the population, definition of the population, and the relation of the population to the audit scope
- iii. Sampling parameters, e.g., sample size (including any consideration regarding sampling risk); random start, method by which random start was obtained; sampling interval

- iv. Sampling method
- v. Items selected and, if non-statistical sampling is used, justification for the selected items
- vi. Details of audit tests performed, including evaluation of errors and, if applicable, alternative audit procedures
- vii. Conclusions reached

### **3.5. Data Collection and Audit Evidence**

#### **3.5.1. Types of Evidence**

IT Auditors should consider using the evidence types such as: -Observed processes and existence of physical items; documentary evidence; representations; and analysis.

3.5.1.1. Observed processes and existence of physical items can include observations of activities, property and IT processes, such as:

- i. A network security monitoring system in operation
- ii. An inventory of media in an offsite storage location

3.5.1.2. Evidence documented on paper or other media can include:

- i. Written policies and procedures;
- ii. Results of data extractions;
- iii. Records of transactions;
- iv. Program listings;
- v. Other documents and records produced in the ordinary course of business; and
- vi. External confirmation from third parties.

3.5.1.3. Written and oral representations of those being audited can include:

- i. Written statements by management, such as representations about the existence and effectiveness of internal controls or plans for a new system implementation.
- ii. Oral representations of such things as how a process works or plans for management follow-up on actions related to the security awareness program.

3.5.1.4. The results of analyzing information through comparisons, simulations, calculations, and reasoning can also be used as evidence. Examples include:

- i. Benchmarking IT performance against other banks or past periods
- ii. Comparison of error rates between applications, transactions, and users
- iii. Re-performance of processes or controls

### 3.5.2. Obtaining Evidence

3.5.1.5. Auditors should obtain sufficient and appropriate evidence to allow them to draw reasonable audit conclusions. This evidence includes:

- i. Procedures performed;
- ii. Results of procedures performed;
- iii. Source documents (in either electronic or paper format), records and corroborating information used to support the audit engagement; and
- iv. Documentation that the work was performed and complies with applicable laws, regulations, and policies.

3.5.1.6. Auditors should also consider alternative evidence to corroborate such representations to ensure their reliability of oral evidence.

3.5.1.7. When gathering evidence, the IT Auditor should consider the:

- i. The time, level of effort and cost of obtaining the evidence compared to the sufficiency of the evidence in reducing audit risk;
- ii. Significance of the matter being evaluated and of the audit procedure requiring the evidence in achieving the audit objectives and reducing audit risk; and
- iii. Electronic evidence may not be retrievable in whole or in part after the passage of time.

3.5.1.8. Evidence can be gathered through the use of manual audit procedures, computer-assisted audit techniques (CAATs) or a combination of both.

3.5.1.9. IT Auditor should select the most appropriate procedure in relation to the audit objective. The following procedures should be considered:

- i. Inquiry and confirmation: The process of seeking information from experienced people who are familiar with the subject matter. The experienced people need not be members of the organ being audited. This procedure can range from formal written inquiries to informal oral inquiries.
- ii. Observation: Observing a procedure or process being performed by those individuals who are typically responsible for its performance or observing physical items such as facilities, computer hardware, or information system settings or configurations. This type of evidence is limited to the point in time when the observation took place. IT Auditor should take into account that observing the

performance of a process or procedure may affect the way the procedure or process is performed.

- iii. Inspection: Examination of internal or external documents and records. Items to be inspected can be supplied on paper or electronic form. Inspection can also include physical asset examination.
- iv. Analytical procedures: Evaluating data by examining possible relationships within the data or between the data and other relevant information. This also includes examining fluctuations, trends and inconsistent relationships.
- v. Recalculation/computation: The process of checking the arithmetical and mathematical accuracy of documents or records either manually or through the use of CAATs.
- vi. Re-performance: Independent performance of procedures and/or controls that were originally executed by the information system or by the bank itself.
- vii. Other generally accepted methods: Other generally accepted procedures that auditors can follow in gathering sufficient and appropriate evidence, such as engaging in social engineering, acting as a mystery guest or conducting ethical intrusion testing.

### **3.5.3. Evaluating Evidence**

- 3.5.3.1. If, in the IT auditor's judgment, the evidence does not meet the criteria, Auditors should obtain additional evidence or perform additional procedures to reduce the limitations or uncertainties related to the evidence.
- 3.5.3.2. When evaluating the reliability of evidence obtained during an audit, IT Auditors should consider the characteristics and properties of the evidence, such as its source, nature (written, oral, visual or electronic), authenticity (presence of digital or manual signatures, date/time stamps) and relationships between evidence that provides corroboration from multiple sources.
- 3.5.3.3. IT Auditors should consider the time period during which information exists or is available in determining the nature, timing and extent of substantive testing and, if applicable, compliance testing.

3.5.3.4. Auditors should obtain evidence that is sufficient and appropriate to enable a qualified independent party to re-perform the tests and obtain the same results and conclusions.

#### **3.5.4. Evidence Documentation**

3.5.4.1. IT Auditors should document the evidence obtained and ensure that documentation is retained and available during a predefined time period, in a format that complies with bank policies and relevant professional standards, laws and regulations.

3.5.4.2. Evidence obtained during the audit test should be appropriately identified, cross-referenced, and cataloged to facilitate determination of the overall sufficiency and appropriateness of evidence.

3.5.4.3. IT Auditors should ensure that documentation of evidence is protected from unauthorized access, disclosure or modification throughout its preparation and retention.

#### **3.6. Using the Work of Other Auditors/Experts**

3.6.1. IT Auditors who do not have the required competencies to perform the audit engagement, either in whole or in part, should consider seeking assistance from other experts with the required skills.

3.6.2. IT Auditors should base their choice of specific experts and the use of other experts' work on objective criteria.

3.6.3. IT Auditors should communicate and document performance requirements to other experts in a contract or agreement prior to the experts beginning work on the engagement.

3.6.4. If the necessary experts cannot be obtained, IT Auditors should document the impact on achieving the audit objectives and include specific tasks in the audit plan to manage the resulting audit risk.

3.6.5. If an audit engagement involves using the work of other experts, the IT Auditors should consider the adequacy of the other experts while planning the IT audit work by assessing the other experts' professional qualifications, competencies, relevant experience, resources and use of quality control processes.

- 3.6.6. IT Auditors should consider the independence and objectivity of other experts before relying on their work.
- 3.6.7. IT Auditors should verify that the audit charter or engagement letter specifies their right of access to the other experts' work.
- 3.6.8. IT Auditors should have access to all work papers, supporting documentation and reports created by the other experts, if such access does not create legal or privacy issues.
- 3.6.9. IT Auditors should consider the activities of other experts and their effects on the IT audit objectives while planning the IT audit work, including:
  - i. Obtaining an understanding of the other experts' scope of work, approach, timing, and use of quality control processes.
  - ii. Determining the level of review required
- 3.6.10. IT Auditors should identify the level of review that is required to provide sufficient and appropriate audit evidence to achieve the overall audit objectives effectively.
- 3.6.11. IT Auditors should review the other experts' final report, methodology or audit programs, and work papers.

### **3.7. Audit Finding Documentation**

- 3.7.1. Auditors should analyze the evidence and information gathered.
- 3.7.2. Significant deviations from expectations should result in findings.
- 3.7.3. Auditors should confirm the findings with the auditee and assess the impact of the findings on other aspects of the control environment.
- 3.7.4. Auditors may propose corrective actions to be taken but should never execute them.
- 3.7.5. If the auditee performs corrective actions that remediate the original finding before the end of the audit engagement, auditors should include the corrective actions taken in the documentation.
- 3.7.6. Auditors should conclude on the findings identified and assess their impact on the audit objectives.
- 3.7.7. Conclusions should be drawn from the original findings. If corrective actions have been performed, an addendum to the conclusion can be formulated explaining the corrective action and the impact of the corrective action on the original conclusion.



- 3.7.8. All the conclusions formulated and whether the audit objectives have been achieved should be documented in the audit engagement report.

### **3.8. Elements of the Audit Findings**

#### **3.8.1. Finding**

- i. Should refer to the results or conclusions of an audit conducted on a particular entity, process, or information system.
- ii. It should be a deviation from expectations that are defined in the policy procedures and applicable laws and standards.
- iii. Should be specific facts or conditions identified during the audit process.
- iv. Should emerge through a process of comparing “what should be” (the criteria) with “what is” (the audit evidence). When there is a difference between “what is” and “what should be,” an assessment of the impact and the effect associated with the variance should be completed and documented as an observation and finding.

#### **3.8.2. Criteria- what should be?**

The standard or benchmark that was identified as the basis against which audit evidence would be compared.

#### **3.8.3. Cause- Why did this happen?**

- i. The possible or likely reason for the difference between the standard or benchmark and the “what is.”
- ii. The cause may be obvious or may be identified by deductive reasoning.
- iii. The identification of similar causes for several findings may highlight an underlying theme to which an audit recommendation should be addressed.

#### **3.8.4. Impact/effect- So what?**

- i. It should indicate the risk or exposure of the Bank as a result of the difference between “what should be” and “what is.”
- ii. The effect should establish the actual or potential significance of what was found. It can be expressed in quantitative terms (e.g. dollars wasted, personnel hours lost, deadlines missed) or qualitative terms (e.g. lack of control, poor reputation with clients).
- iii. To warrant reporting, an effect should be sufficiently serious to justify the action (and related cost) to correct the deficiency (the difference).

- iv. Anticipated risks are the effects of the findings in the organization. It implies the probable occurrence/ or the expected risk manifested due to the gap/finding.

#### **3.8.5. Recommendations- what should be done?**

- i. Should indicate the actions suggested or required to correct the situation and prevent future occurrences.
- ii. There should be a clear and logical relationship between the recommendation and the underlying cause of the deficiency, findings, and related criteria.
- iii. Recommendations are based on findings and conclusions. They call for action to correct existing conditions or improve operations.
- iv. Recommendations may suggest approaches to correcting or enhancing performance as a guide for management in achieving desired results.
- v. In developing sound recommendations, the auditor should ensure that the recommended action is within the scope of the auditee, addresses the cause and not just the symptoms, and is at least intuitively viable.

#### **3.8.6. Auditees Response- what will be done?**

- i. Response to the audit observation and finding and their action plan to address the recommendation.
- ii. This should be given by the auditees, and the auditors do not have the right to change it.
- iii. It should be related to the findings, and it is an indication that the auditees have already seen the findings enclosed.
- iv. If the auditees are not willing to provide response within specified time, the findings are assumed to be accepted by the auditees.

#### **3.8.7. Auditors' Justifications**

- i. Is the auditor's response to justify the auditee's response in case the auditee do not agree to the auditors' observations or findings;
- ii. It should be given by the auditors engaged on the audit work.

### **3.9. Types of Audit Findings**

Audit findings can be categorized into three groups based on their significance.

- 3.9.1. Insignificant Findings: Insignificant findings, such as clerical/human errors, need not be formally raised with auditee's management. In these circumstances, the

audit team shall discuss the issue with the responsible staff, ensure that the situation is corrected and note down the matter in the working papers designed for the purpose. However, the audit team shall bring clerical errors that appear on a recurring basis to audited management's attention, as their recurrence may be an indication of or lead to develop a larger problem.

- 3.9.2. Minor Findings: A minor finding is more than a clerical/human error that, if not corrected, will have an adverse effect on the Bank. Though it may not hamper any of the Bank's operating objectives, it is necessary to bring it to the attention of the auditee's management.
- 3.9.3. Major Findings: A major finding is one that would prevent or deter the Bank or the auditee from achieving its objectives. The audit team should, therefore, know as much about the finding that it is raising and the facts on which it is basing so that the finding must be indisputable.

### **3.10. Working Paper**

- 3.10.1. All audit plans, programs, activities, tests, findings, and incidents should be properly documented in work papers.
- 3.10.2. The format and media of work papers can vary, depending on specific needs of the process.
- 3.10.3. IT Auditors should particularly consider how to maintain the integrity and protection of audit test evidence to preserve its value as substantiation in support of audit results.
- 3.10.4. Work papers should provide a seamless transition with traceability and support for the work performed from objectives to report and from report to objectives. In this context, the audit report can be viewed as a particular work paper.
- 3.10.5. Auditors should prepare, in a timely manner, sufficient, appropriate, and relevant documentation that provides a basis for conclusions and that contains evidence of the review performed.
- 3.10.6. Sufficient, appropriate, and relevant documentation should enable a prudent and informed person with no previous connection to the audit engagement to re-perform the tasks performed during the audit engagement and reach the same conclusion. Documentation should include:

- i. Audit engagement objectives and scope of work.
- ii. Audit engagement project plan.
- iii. Audit work program.
- iv. Audit steps performed.
- v. Evidence gathered.
- vi. Conclusions and recommendations

3.10.7. The documentation should be organized in a way it can: -

- i. Identify audit team members who performed each audit task and specifies their roles in preparing and reviewing the documentation.
- ii. Records the evidence requested.
- iii. Supports the accuracy, completeness and validity of the work performed.
- iv. Provides support for the conclusions reached.
- v. Facilitates the review process.
- vi. Documents objectives of the engagement.
- vii. Provides the basis for a quality improvement program.

3.10.8. Performance and supervision activities should be documented in audit engagement work papers.

3.10.9. Audit Management should also determine the media carriers to be used and the storage and retention procedures for the work papers.

3.10.10. Auditor should ensure that documentation of the work performed is completed on a timely basis.

3.10.11. All information and evidence required to form a conclusion or opinion should be obtained prior to the issue date of the audit report.

3.10.12. Audit engagement work papers should include the date they were prepared and reviewed.

### **3.11. Conclusion**

3.11.1. Upon completion of the fieldwork, the auditor summarizes the audit findings, anticipated risks, recommendations, and auditee response, necessary for the audit report draft.

3.11.2. At the conclusion of the fieldwork, IT Auditors draft the audit finding summary report.

- 3.11.3. IT Auditors thoroughly review the audit working papers and discuss the draft before it is presented or sent to the client. This discussion draft is submitted to the client's review and response before the exit conference,
- 3.11.4. Auditee should prepare a detailed action plan for the findings, explain how reported findings will be resolved and include an implementation timetable. The prepared action plan is used by the IT Auditors/Follow-up Team as checklist for the follow-up audit.
- 3.11.5. IT Auditors must schedule and confirm with the auditee regarding the time of exit conference.

### **3.12. Exit Conference**

- 3.12.1. When the draft finding summary is submitted to the auditee, IT Auditors must meet with the client management to discuss the findings, the risks and the forwarded recommendation. At this meeting, the client comments on the draft and the IT Auditors reach an agreement on the audit findings;
- 3.12.2. Ensure mutual understanding of the audit findings by both parties;
- 3.12.3. Highlight the internal control loopholes detected during the audit to the audit client management;
- 3.12.4. Urge the auditee management to subsequently send audit rectification report as per the agreed action plan;
- 3.12.5. Advise the auditee not to limit themselves on rectifying reported audit findings only, identify other similar findings that may materialize on the day-to-day operation to enable them to take appropriate control measure;
- 3.12.6. Acknowledge their cooperation towards the successful accomplishment of the audit task;
- 3.12.7. After the exit conference, auditee can amend responses provided previously based on the agreement during exit conference.

## Part Four

### 4. IT Audit Reporting

#### 4.1. General Overview

The Reporting Standard provides all aspects that should be included in an audit engagement report and provides IT Auditor with considerations to make when drafting and finalizing an audit engagement report.

#### 4.2. Reviewing the Management Action Plan

- 4.2.1. Under the Internal Audit Charter; auditee management is required to develop an action plan to address recommendations made by the internal auditor. Normally, the action plan should indicate where there is:
- i. Agreement with the recommendation and a commitment to undertake corrective action;
  - ii. Agreement with the recommendation and an explanation as to why corrective action cannot be taken at this time; or
  - iii. Disagreement with the recommendation with an explanation.
- 4.2.2. IT auditor should review the action plan to determine whether it adequately addresses the recommendations outlined in the report. In particular, the IT auditor will want to ensure that:
- i. The proposed action will resolve the underlying problem(s) and will produce concrete results;
  - ii. The audit entity has the capacity and authority to complete the actions; and
  - iii. It is clear who is responsible for doing what and within what time frame.
- 4.2.3. The review of the action plan will also help the IT auditor determine the most appropriate follow-up action, e.g. regular status reports or scheduled on-site verification.
- 4.2.4. If IT auditor is not satisfied with the response or the action plan, a meeting should be scheduled with the auditee to present the auditor's concerns and to suggest means by which the action plan might be improved. In the event that direct discussion with the auditee does not lead to a more acceptable plan, the IT auditor may choose to raise the issue with more senior management or may wish to express his or her concerns when the report is presented to the Board Audit Committee and the Board, as long as the intention to do so has been communicated to the auditee.

- 4.2.5. In order to provide the Board Audit Committee and the Board with a fair and complete picture, the management action plan should be integrated into the IT audit report. This integration should be done in such a way as to clearly identify, for each recommendation provided in the report, the action to be taken, the position or person responsible, and the related timing of implementation.
- 4.2.6. In any situation where an auditee management action plan is not forthcoming within the defined time frame (3 weeks), the IT audit report should be presented to the Board Audit Committee and the Board as a completed report without the management action plan.

### **4.3. Audit Engagement Report**

- 4.3.1. The audit report must state compliance with internal Audit Standards, ISACA's standards, or other relevant professional standards. Any noncompliance with these standards should be explicitly noted in the report.
- 4.3.2. IT auditors should discuss the draft report contents with management in the subject area prior to finalization and release, and include management's response to findings, conclusions, and recommendations in the final report.
- 4.3.3. The audit team should not incorporate on the spot rectified findings on the audit report, but record on its working papers.
- 4.3.4. IT Auditors should include the scope of the audit engagement in the audit report.
- 4.3.5. The scope shall include description of the audit subject or activity, the period under review and the period when the audit was performed, the nature and extent of the work performed, and any qualifications or limitations in scope.
- 4.3.6. The audit report should include a summary of the work performed, which will help the intended users of the report to better understand the nature of the assurance provided.
- 4.3.7. The audit report should include a section with the opinion of the auditor in developing an audit report.
- 4.3.8. IT Auditor should consider all relevant evidence, regardless of whether it appears to corroborate or contradict the subject matter information.
- 4.3.9. Opinions should be supported by results of the control procedures based on identified criteria.

- 4.3.10. IT Auditor should conclude whether sufficient and appropriate evidence has been obtained to support the conclusions in the audit engagement report.
- 4.3.11. The report should express an opinion about whether, in all material respects, the design and/or operation of control procedures in relation to the area of activity were effective.
- 4.3.12. The audit report should note that the maintenance of an effective internal control structure, including control procedures for the area of activity, is the responsibility of management.
- 4.3.13. The audit report should include identification of the audit objectives.
- 4.3.14. The audit report should include a description of the criteria or disclosure of the source of the criteria. Furthermore, IT Auditor should consider disclosing:
  - i. Any significant interpretations made in applying the criteria;
  - ii. Measurement methods used when criteria allow a choice among several measurement methods; and
  - iii. Changes in the standard measurement methods used.
- 4.3.15. The audit report should include intended recipients and any restrictions on circulation.
- 4.3.16. The audit report should include the date of issuance of the audit engagement report.
- 4.3.17. The audit report should mention that distribution (i.e., intended recipients and any restrictions on circulation) is in accordance with the terms of the audit charter or engagement letter.
- 4.3.18. The audit report should include observations, findings, recommendations, auditee's responses and conclusions.
- 4.3.19. For each management response, IT Auditor should obtain information on the proposed actions to implement or address reported recommendations and the planned implementation or action date.
- 4.3.20. If IT Auditor and the auditee disagree about a particular recommendation or audit comment, the engagement communications may state both positions and the reasons for the differences.
- 4.3.21. The auditee's written comments may be included as an appendix to the audit report, in the body of the report or in a cover letter.
- 4.3.22. Upon completion of audit engagement, the audit team prepares the final report which may incorporate the following;



- i. Cover page: showing the title of the audit, name of auditee and audit date or period;
- ii. Executive summary: it contains major findings, conclusions and actions to be taken.
- iii. Introduction: Describes the process/sub-process or activity being audited, start and completion date of the audit, objective and scope of the audit, audit methodology and any background information necessary to acquaint the reader.
- iv. Detailed findings with auditee responses: this is the main audit report that will contain major and minor findings, along with audit recommendations and auditee's responses with target dates for corrective action.
- v. Annexes, exhibit and attachments (if any).
- vi. Quarterly Progress Report

Every quarter, Chief Internal Auditor summarizes major audit findings identified in each quarter with the rectification status findings identified during the previous period and communicates the prepared quarterly report to the Board of Directors, Board Audit Committee members, and the Chief Executive Officer for appropriate intervention/attention and/or any remedial action. Every quarterly progress report of Internal Audit Process should incorporate the followings;

- a. Cover page: bear name of the Process (Internal Audit) and audit period/ quarter;
- b. Executive Summary: High level abstracts of the report;
- c. Introduction: States the reporting quarter, major focus areas of the quarter and organization of the report;
- d. Actual vs Plan Performance: the actual performance against the approved activity plan.
- e. Major/Significant findings: will be presented in a tabular form. Containing Major/Significant findings, impacts and recommendations;
- f. Follow-up report: containing unrectified major/significant findings that were presented to the Top Management/BOD attention/intervention and/or action in the previous progress reports. It should be presented incorporating (a) Major or/ significant findings, effect, recommendations and status of the findings (in terms of rectification) and (b) summary of the status of all findings. The table should also contain total number of findings, rectified findings, and un-rectified findings.
- g. Conclusion; and
- h. Annexes if necessary

#### **4.4. Semi-Annual and Annual Summary Report**

- 4.4.1. The Semi-annual and annual summary report is prepared by IT Audit Management and reviewed and corrected by the Chief Internal Auditor.
- 4.4.2. The list of audit engagements performed should be mentioned including the most important findings/recommendations together with the response of the auditee. Errors and irregularities of high importance for the period is another information to take into consideration for being communicated.
- 4.4.3. As good practice, the semi-annual/annual overview should be limited to 1 to 25 pages. An annex may provide an overview of important findings/recommendations from past periods that have not been resolved.
- 4.4.4. The annual report shall include the same important topics as was stated for the semi-annual report: performance of the annual audit plan including an overview of numbers and names of audit engagements finished, started and not performed. The overview of the most important recommendations for each audit including the answers from the auditees should be provided as well to the Board and relevant senior management. The annual overview of errors and irregularities of high importance is information to communicate.
- 4.4.5. If the Chief Internal Auditor has important messages to communicate to highlight tendencies in the Bank towards respect for risk management, internal control or corporate governance, this might be an interesting topic to cover in the overview of the annual report.

#### **4.5. Error and Omission of Report**

If a final communication contains a significant error or omissions, the Chief Internal Auditor should communicate corrected information to all parties concerned.

#### **4.6. Closing the Audit Engagement**

- 4.6.1. Once the audit report is finalized and issued, IT audit should effectively close out the engagement and determine the nature of and process for required follow-up activities.
- 4.6.2. The following are some of the key closing-out activities to be performed:
  - i. Finalize and archive working papers;
  - ii. Complete project performance evaluations for each IT auditor on the engagement and compile lessons learned; and

- iii. Provide input to audit plans, e.g. update the audit object scoring, profile and the permanent file, and recommend follow-up activity.
- 4.6.3. IT Auditor should obtain written representation from management that no subsequent events have occurred.
- 4.6.4. IT auditors should communicate significant deficiencies and weaknesses in the control environment to those charged with governance and, where applicable, to the responsible authority. They should also explicitly disclose in the report that the deficiencies and weaknesses have been communicated.
- 4.6.5. IT auditors should communicate to management any internal control deficiencies that are less than significant but more than inconsequential. In such cases, IT Auditor should notify those charged with governance or the responsible authority that such internal control deficiencies have been communicated to management.

## Part Five

### 5. IT Audit Follow-Up

#### 5.1. General Overview

Follow-up activity is a process through which IT Auditor determine the adequacy, effectiveness and timeliness of actions taken by management on reported observations and recommendations, including those made by external auditors and others.

- 5.1.1. IT Auditor shall monitor and periodically report to those charged with governance and oversight of the audit function (e.g., the board of directors and/or the audit committee) management's progress on findings and recommendations.
- 5.1.2. The report should include a conclusion on whether management has planned and taken appropriate, timely action to address reported audit findings and recommendations.
- 5.1.3. Progress on the overall status of the implementation of audit findings should be regularly reported to the audit committee if one is in place.
- 5.1.4. Where it is determined that the risk related to a finding has been accepted and is greater than the Bank's risk appetite, this risk acceptance should be discussed with senior management. The acceptance of the risk (particularly failure to resolve the risk) should be brought to the attention of the audit committee (if one is in place) and/or the board of directors.
- 5.1.5. IT Auditor should obtain agreement on the results of the audit engagement and on a plan of action to improve operations, as needed.
- 5.1.6. Proposed actions should be provided to IT Auditor and should be recorded as a management response in the final report with a committed implementation and/or action date.
- 5.1.7. If IT Auditors and the auditee come to an agreement on the proposed actions, IT Auditor should initiate the procedures for follow-up activities.

#### 5.2. Follow up procedure

The follow-up task continues until satisfactory corrective actions are taken.

It is advisable to consider the following steps in the course of this endeavor.

- 5.2.1. Carefully analyzing the auditee's rectification report.

- 5.2.2. Factors that should be considered in determining appropriate follow-up procedures include:
- i. Importance and impact of the findings and recommendations on the IT environment or IT application at issue.
  - ii. Any changes in the IT environment that may affect the importance and impact of the findings and recommendations.
  - iii. Complexity of correcting the reported situation;
  - iv. Time, cost and effort needed to correct the reported situation; and
  - v. The effect, if correcting the reported situation should fail.
- 5.2.3. Discuss with the auditee (either in person or through telephone) any portion of the rectification report that is unclear or not rectified. Any audit finding or suggestion misinterpreted needs to be clarified.
- 5.2.4. Conduct on-site reviews (follow up audit) of corrective actions and the resultant or prevailing conditions of major findings (if deemed necessary). This is to determine if anticipated improvements in terms of rectification were achieved. Methods of on-site review include interviews, direct observation, tests and examining the documentation of corrective actions.
- 5.2.5. The auditee is expected to rectify on or before target date but report at the end of that month. If the auditee does not respond/rectify at all within the target date and report at the end of that month, the following steps shall be taken:
- i. Reminding the auditee to respond/rectify by telephone within 7 days from the end of that month;
  - ii. In the event that no response is received, send a written reminder to the auditee, after waiting 7 working days from telephone conversation date, with a copy to the next higher body.
  - iii. If the auditee does not respond after the written reminder within 7 days, IT Audit shall report the situation to the Executive Management Committee and/or Board Audit Committee.
- 5.2.6. Producing a follow-up report: The report should contain items listed out under progress report.
- 5.2.7. During the next regular audit, reviewing action plan implementation of past audit can be incorporated in the scope of the current audit.

- 5.2.8. Audit rectification status follow-up sheet should be systematically used for documenting the follow-up process of the IT Audit.
- 5.2.9. Decisions on the timing of follow-up activities should consider the significance of the reported findings and the effect on Bank's strategy and objectives if corrective actions are not taken.
- 5.2.10. Timing of follow-up activities in relation to the original reporting is a matter of professional judgment dependent on several considerations, such as the nature or magnitude of associated risk and costs to the Bank.
- 5.2.11. Follow-up activities should be scheduled, along with the other steps necessary to perform each review.
- 5.2.12. IT Auditor should follow up on agreed-on outcomes relating to high-risk issues soon after the due date for action and may monitor them progressively.
- 5.2.13. IT Auditors should follow up on individual management responses according to the due date agreed on with management.
- 5.2.14. The auditee should be given a time frame within which to provide details of actions taken to implement recommendations.
- 5.2.15. The auditee should provide details of recommendations implementations based on the given time.
- 5.2.16. Management's response detailing the actions taken should be evaluated, if possible, by the IT Auditor who performed the original review. Wherever possible, audit evidence of actions taken should be obtained.
- 5.2.17. If doubts arise about the information or effectiveness of implemented recommendations, the IT Auditor should conduct testing or other audit procedures to verify the accuracy before proceeding with further follow-up activities.
- 5.2.18. IT Auditor should evaluate whether unimplemented recommendations are still relevant or have a greater significance.
- 5.2.19. A follow-up engagement may have to be scheduled to verify the implementation of critical and/or important actions.
- 5.2.20. IT Auditor' opinions on unsatisfactory management responses or actions should be communicated to the appropriate level of management.
- 5.2.21. The most effective way to receive follow-up responses from management is in writing because a written response helps to reinforce and confirm management's responsibility

for follow-up action and progress achieved. Also, written responses ensure an accurate record of actions, responsibilities, and current status.

- 5.2.22. IT Auditor should request and/or receive periodic updates from management responsible for implementing agreed-on actions to evaluate the progress management has made, particularly in relation to high-risk issues and corrective actions with long lead times.
- 5.2.23. Management may decide to accept the risk of not correcting a reported condition because of cost, complexity of the corrective action or other considerations. The board of directors, or those charged with governance, should be informed of recommendations for which management accepts the risk of not correcting the reported situation.
- 5.2.24. Acceptance of risk should be documented and formally approved by executive management and communicated to those charged with governance.
- 5.2.25. If IT Auditor believe that the auditee has accepted a level of residual risk that is inappropriate for the Bank's, they should discuss the matter with Chief, Internal Auditor and Executive Management. If Chief Internal Auditor remain in disagreement with the decision regarding residual risk, they, along with Executive Management, should report the matter to the board, or those charged with governance, for resolution.

### **5.3. Reporting of follow-up**

- 5.3.1. IT auditors in coordination with audit follow up team should provide a status report on agreed corrective actions, including recommendations not implemented, and should be presented to the appropriate level of management and to those charged with governance (the audit committee).
- 5.3.2. If the IT Auditor identifies inaccurate reports regarding unimplemented findings, they must promptly inform relevant management and governance authorities. Additionally, they should seek an updated corrective action plan and implementation date if necessary.
- 5.3.3. IT Auditors should forward a report detailing all the implemented and/or completed actions to Executive Management and those charged with governance.
- 5.3.4. IT Auditors should prepare a concise report that shall be complete and sent to Executive Management and governance authorities.
- 5.3.5. IT audit Functions should establish automated tracking system or database that can assist in carrying out follow-up activities.

## Part Six

### 6. IT Audit Consulting Services

With the pace of digital transformation, IT auditors may find themselves at a crossroads. Not only do they need to keep up with new technologies, but they are being asked to advise on whether those technologies should be adopted, and what controls are needed for the newly adopted technologies. With automation, some auditors are finding their roles within an enterprise shifting; they are being asked to provide their expertise in an advisory or consultative capacity. While these shifts in roles allow IT auditors to remain relevant, they also raise potential objectivity and independence concerns.

#### 6.1. General Overview

- 6.1.1. Consulting services are advisory in nature and are generally performed at the specific request of an engagement client.
- 6.1.2. The nature and scope of the consulting engagement are subject to agreement with the engagement client.
- 6.1.3. Consulting services generally involve two parties: (1) the person or group offering the advice - the internal auditor, and (2) the person or group seeking and receiving the advice - the engagement client.
- 6.1.4. When performing consulting services, the IT auditor should maintain objectivity and not assume management responsibility.
- 6.1.5. IT auditors in an advisory service role should collaborate with management to identify areas for improvement, propose effective solutions, and assist in the implementation of risk management strategies.
- 6.1.6. IT auditors shall serve as trusted advisors and contribute to the organization's success by ensuring that IT investments align with business goals, promoting efficiency, and enhancing overall security and compliance.

#### 6.2. Responsibilities of IT Auditors in Advisory Service

- 6.2.1. Help in applying current knowledge of IT trends, techniques, and risks to identify security and risk management improvement opportunities to enhance value to the Banks.
- 6.2.2. Shall identify internal controls issues within the Banks IT environment and develop gap analyses.



- 6.2.3. Shall develop understanding of core IT processes and look for opportunities to help IT management in gaining process efficiencies and control optimization.
- 6.2.4. Shall advise on what controls are needed for the newly adopted technologies.
- 6.2.5. Shall provide risk advisory services, in identifying, developing and testing internal control policies and procedures within a bank's information technology environments.

### **6.3. Planning**

- 6.3.1. Consulting services are advisory and related client service activities, the nature and scope of which are agreed with the client, and which are intended to add value and improve Bank's governance, risk management and control processes without affecting the independence of IT Audit.
- 6.3.2. It is generally performed at the specific request of the Chief Executive Officer and/or the Board of Directors as stated in the Internal Audit Charter.
- 6.3.3. Before accepting the request, the Chief Internal Auditor makes sure that the requesting body sets clearly the following items:
  - i. Specific type of consulting activity needed
  - ii. The objective/purpose of consulting service
  - iii. The scope of the consulting services
  - iv. Reporting period and
  - v. Terms of engagement
  - vi. The Chief Internal Auditor should consider the following while undertaking consulting engagement:
    - a. Review the client's request;
    - b. Determine the skill and resource needed to conduct the engagement; and
    - c. Assess the impact on the accomplishment of previously approved audit plan.
- 6.3.4. If impairments to independence/objectivity exist or may happen during the engagement, disclosure should be made to the requesting organ prior to accepting/during the engagement.
- 6.3.5. The Chief Internal Auditor may decline consulting engagement or obtain competent advice if internal audit staff lacks knowledge, skill and competence needed to perform all or part of the engagement. Those accepted should be included in annual plan of the Internal Audit.
- 6.3.6. The consulting engagement objective should address risks, controls, and governance processes to the extent agreed up on with the client.

6.3.7. The IT audit team to be assigned to provide consulting services should have an understanding about the objectives, scope and design of service to ensure that professionalism, integrity, credibility and reputation of internal auditing is maintained. Any reservation should be communicated to service receivers.

6.3.8. The objectives of consulting engagement should meet needs of recipients of services.

#### **6.4. Independence and objectivity**

6.4.1. IT auditors should maintain their objectivity when performing consulting service. If impairment exists prior/during engagement, disclosure should be made to management immediately.

6.4.2. Impairment may occur if assurance service is performed within a year after a formal consulting engagement. Steps that should be taken to minimize effects of impairment include:

6.4.2.1. Assigning different auditors to perform each of the service;

6.4.2.2. Establishing independent management and supervision;

6.4.2.3. Defining separate accountability for the result of the projects; and

6.4.2.4. Disclosing the presumed impairment.

6.4.2.5. It is the responsibility of Management whether to accept and implement recommendations or not.

6.4.3. IT auditors should not inappropriately or unintentionally assume management responsibilities (that was not intended in original objectives and scope of engagement) especially if consulting engagement is ongoing and continuous.

#### **6.5. Due professional care**

IT auditors should exercise due professional care in consulting engagement by considering:

6.5.1. Needs and expectations of engagement client including nature, timing, communication result.

6.5.2. Relative complexity and extent of work needed to achieve engagement objective.

6.5.3. Cost in relation to potential benefit of the engagement.

6.5.4. Skills and resources needed in conducting the engagement.

6.5.5. Effects on the scope of audit plan previously approved by audit committee;

6.5.6. Potential organizational benefit driven from engagement;

6.5.7. Possible motivations and reasons for those requesting service; and

6.5.8. Potential impact on future audit assignments and engagement.

## **6.6. Engagement**

- 6.6.1. During the consulting engagement, IT auditors should address risk and control consistent with engagement objective and alert to the existence of other significant risks and control weaknesses.
- 6.6.2. In performing consulting engagement, IT auditors should make sure that scope of the engagement is sufficient to address agreed upon objectives. If IT auditors develop reservation about scope during the engagement, the reservation should be discussed with the client to determine whether or not to continue the engagement.

## **6.7. Reporting**

- 6.7.1. In consulting engagement, reporting requirements are usually set by requesting parties. However, the format should describe the nature of the engagement and other factors, e.g. restrictions, for which users should be aware.
- 6.7.2. IT audit should disclose to management and Board of Directors/Audit Committee of the work done regarding consulting engagement.
- 6.7.3. Communication of progress and results of consulting engagement will vary in form and content depending on nature and need of client.
- 6.7.4. Results may need to be communicated beyond those who receive or request consulting services.
- 6.7.5. The Chief Internal Auditor is responsible for communicating final result of consulting engagement to client. When risks identified as regard to internal control, risk management and governance issues are believed to be significant, it should be communicated to the Chief Executive Officer and/or the Board as the case may be.

## **6.8. Follow up**

IT audit function could monitor disposition of results of consulting service to the extent agreed upon with the client. Monitoring effort may depend on various factors such as management explicit interest in engagement, or IT auditor's assessment of the project's risks, or value to the Bank.

## Part Seven

### 7. Quality Assurance and Continuous Improvement

#### 7.1. Engagement Supervision

- 7.1.1. Every task executed during an audit engagement by the IT audit team members should be under oversight of the Auditor who have supervisory responsibilities to ensure that audit objectives and applicable professional audit standards are met.
- 7.1.2. The extent of supervision required will depend highly on the skills, knowledge and experience of auditors executing the task under review, and on the complexity of the audit engagement.
- 7.1.3. Supervision is a process that is present in every step of the audit engagement. Supervision includes:
- i. Ensuring the IT audit team members have the combined skills, knowledge and experience to complete the audit engagement successfully.
  - ii. Ensuring an appropriate audit engagement project plan and audit program are set up and approved.
  - iii. Reviewing the audit engagement work papers.
  - iv. Ensuring that audit engagement communication with auditees and other relevant stakeholders is accurate, clear, concise, objective, constructive and timely.
  - v. Ensuring that the approved audit engagement work program is completed at the end of the audit engagement, unless changes are justified and approved in advance, and that the audit engagement objectives are met.
  - vi. Providing opportunities for IT audit team members to develop their skills and knowledge.
- 7.1.4. Reviewing audit engagement work papers is required to ensure that all necessary audit procedures are performed; evidence gathered is sufficient and appropriate; and conclusions adequately support the findings of the audit, engagement objectives, and conclusion or opinion.
- 7.1.5. Considering the objectives, the review should be performed by IT audit team members who have supervisory responsibilities over the IT Auditors who perform the audit work.
- 7.1.6. During the review process, reviewers should record questions as they arise. When auditors respond to questions, care should be taken to retain evidence showing that questions were raised and answered.

- 7.1.7. Evidence of review should be documented and retained. Options to document evidence of performing a review include but are not limited to:
- i. Signing and dating each audit engagement work paper after review.
  - ii. Completing an audit engagement work paper review checklist.
  - iii. Preparing a signed document that provides a reference to the audit engagement work papers under review and details the nature, timing, extent and result of the review.
  - iv. Both digital and hard copy executions of all these options are valid.
- 7.1.8. Supervision allows for development and performance evaluation of auditors. Reviewers have a privileged view of the work performed by other IT audit team members, which allows for a detailed and adequate evaluation of their performance. Reviewers should point out areas of development that can improve performance and advise on ways to advance skills and knowledge.

## **7.2. Quality Assurance**

- 7.2.1. It is the responsibility of the Chief Internal Auditor to develop and maintain a quality assurance and improvement program that covers IT audit activities.
- 7.2.2. An effective quality assurance and continuous improvement program should guide the audit process to achieve and deliver internal audits with a high-quality level that effectively and consistently result in a value-added service.
- 7.2.3. An effective audit activity quality assurance program normally operates at three levels:
- i. Within the conduct of a specific audit engagement, (Engagement Supervision)
  - ii. Within the Internal Audit Process, (ongoing quality review and Periodic quality review)
  - iii. Outside the Internal Audit Process. (Periodic quality review by competent persons from other processes of the Bank and external quality assessment by external reviewer)
- 7.2.4. An effective quality assurance program should:
- i. Ensure that engagements are in compliance with the Internal Audit Charter as well as with the IIA standards;
  - ii. Ensure that the services provided are effective, efficient, timely, and of good quality;
  - iii. Clarify and reinforce the effectiveness of policies, procedures, approaches, tools, and techniques used by internal auditors and identify good practices; and
  - iv. Provide IT audit staff and management with the basis and criteria for continuous improvement of their activities.

### 7.3. Internal Assessment

- 7.3.1. The first and most important level of quality assurance is the due professional care exercised by the internal auditor and the **supervisory review** conducted on the internal auditor's work throughout all phases of the internal audit engagement by senior members of the internal audit function.
- 7.3.2. The supervisory review must encompass the planning, conduct, and reporting phases. To support these reviews, a number of checklists, referenced throughout this Risk Based IT Audit Procedure at the appropriate step for their use, are provided in the appendices.
- 7.3.3. The internal assessments include ongoing reviews of the performance of the internal audit activity and periodic reviews.
- 7.3.4. Ongoing Quality Reviews;  
Ongoing quality reviews involve ongoing reviews of the performance of the internal audit activity and engagement supervision which can be described as follow;
- i. Use checklists and other means, to provide assurance that process adopted by the internal auditors agrees with the Internal Audit Procedure. Checklists designed for obtaining review information which are descriptive in nature; the items on the checklists are covering all steps needed in the execution of the audit engagement as well as the expected level of quality to be present during the performance of each audit step.
  - ii. Working paper review. Audit Template N° 13 identified as "Audit work paper review" is controlling the quality of the performance of the executed steps in the audit program.
  - iii. Checklists designed to **measure** the quality performance of all steps in the execution of the audit engagement. Audit template N° 10 identified as "Audit productivity measurement: auditors in charge" is a helpful tool for the Internal Audit Process to assess the quality performance of the internal audits.
- 7.3.5. Internal Periodic Quality Reviews
- i. The First level of internal periodic quality assurance to be performed by the Internal Audit Process is an internal review to assess the quality and adequacy of the Process in accordance with the Internal Audit Charter, Internal Audit Procedure, the IIA and ISACA Audit Standards and the Code of Ethics. The Internal Audit Process may choose to have internal reviews conducted by one or more internal auditors or may choose to rotate responsibilities among all staff on a less formal basis to share the learning experience and benefits of the internal reviews.

- a. Opinion surveys of stakeholders (auditees, Management, Board, etc.);
  - b. Performance evaluation;
  - c. Actual vs. plan analysis;
  - d. Shall be performed by Certified Internal Auditors (CIAs), if available, or other competent audit professionals currently assigned elsewhere in the Bank; and
  - e. Internal Audit management members share experience/draw lessons by getting together every quarter and discussing as to which activities were done well and how, which were less successful and why.
- ii. Periodic review shall be conducted in the presence of all IT auditors at least on a yearly basis except a year in which external quality assessment is made.
  - iii. The Second level of Periodic Internal Quality Review may be performed every two years by other people from the other processes within the Bank with knowledge of Internal Audit practices and the Internal Audit standards.

#### 7.3.6. External Quality Assessments

- i. The third level of quality assurance is intended to comply with the IIA requirement that Internal Audit Process should undergo a formal comprehensive **external review** of effectiveness and compliance with relevant IIA standards at least once every five years.
- ii. The external quality assurance review should address all aspects of the work of the internal audit function and should be performed preferably by qualified external reviewers who are independent of the internal audit function being reviewed.
- iii. The IIA has developed a methodology (described in the Quality Assessment Manual) and a number of standard tools and work instruments, such as questionnaires to gauge senior management perspectives that should be employed in the external review process.
- iv. A qualified, independent reviewer or review team outside the Bank shall conduct external assessment. The Chief Internal Auditor shall be involved in the selection process of external reviewer and obtain the approval of the Board of Management.
- v. The external reviewers should fulfill the following selection criteria:
  - a. Competency in the professional practice of internal auditing and/or in the external assessment,
  - b. The members of the review team and any other individuals who participate on the assessment should be free from any real or apparent conflict of interest with Coopbank or Coopbank's internal audit personnel.

- vi. The scope of external assessment includes at least the following:
  - a. Compliance with the IIA's and ISACA's Standards and Code of Ethics;
  - b. Compliance with Internal Audit Charter, plans, procedure, practices, and regulatory requirements;
  - c. The integration of the internal audit activity with the Bank's strategies;
  - d. The tools and techniques employed by internal audit activity;
  - e. The mix of knowledge, experience and disciplines within the Internal Audit staff and
  - f. To determine whether the internal audit activity adds value and improves the Bank's operations.
- vii. Queries and deficiencies identified during the quality assurance review process should be documented, and an action plan should be developed to address significant deficiencies.
- viii. A report should be established at the completion of each internal periodic review. The report indicates the degree of compliance with the IIA and ISACA standards and the level of audit effectiveness and provides recommendations for improvement usually focusing on the internal audit process, resources allocation, audit techniques used, working papers, quality of audit evidence collected, interactions with auditees and the internal audit reporting.

#### **7.4. Auditee Satisfaction**

As an additional means to ensure the quality and relevance of its services, the Internal Audit Process might obtain feedback from the auditee on the proficiency and effectiveness of work performed. An "Audit customer survey" is provided in Audit Template N°17 to illustrate the elements on which feedback might be sought. The use of such a survey would normally be accompanied by a covering letter or memorandum explaining the purpose of the survey and how the information obtained will be used. The cover note would also describe the process for submitting the completed questionnaire.

An auditee survey could also form part of an internal independent quality assurance review and is a mandatory element of external quality assurance reviews.



## Part Eight

### 8. General Administration

General administration in the context of this procedure refers to the recording of information obtained in due course of auditing, keeping the working papers, access control of audit records, retention mechanism of audit records, and other affairs like ways of coordination with external auditors and regulatory organ on matter of auditing.

#### 8.1. Recording information and keeping of working papers

While conducting assurance services, the Audit Team should sufficiently record the information obtained and the analysis made in the working papers and the information should support the basis for the recommendations to be reported during the audit. Audit working paper should be kept in the custody of internal audit process.

8.1.1. As a general guideline, audit working papers should have the following attributes:

- i. Completeness and accuracy;
- ii. Clarity and simplicity;
- iii. Readability and neatness; and
- iv. Relevant and appropriate level of detail.

8.1.2. IT auditors should document work performed to achieve objective of consulting engagement and support its results. However, documentation requirements applicable to assurance engagement do not necessarily apply to consulting engagement. Working paper for consulting engagement may vary in form and content depending on nature of engagement.

8.1.3. IT Auditors should follow the following techniques when preparing audit working papers.

8.1.3.1. Each audit working paper should have a heading, which will include the name of the auditee and the items being examined. If the working papers are letters, copies of original documents, copies of memoranda, etc., assign page numbers to each sequentially.

8.1.3.2. Each audit working paper should include the date of audit and be signed (or initialed) by the auditor performing the work.

8.1.3.3. Each audit working paper should contain an index or reference number. Working paper preparation commences before audit work begins and typically presented at the team meeting and continues through audit process. The page number can be assigned either by numbering of pages sequentially from beginning to end or by differentiating working papers by a combination of letters and numbers.

8.1.3.4. Source of data should be clearly identified.

8.1.3.5. Where tick marks are used in working papers, the internal auditor preparing the working paper should include an explanation about the tick mark.

8.1.4. Audit work papers also include the following:

- i. Planning documents and engagement programs.
- ii. Internal Control Questionnaires, flowcharts, checklist and narratives.
- iii. Notes and memorandum resulting from interviews.
- iv. Organizational data, such as organization charts and job descriptions.
- v. Copies of important contracts and agreements.
- vi. Information about operating and financial policies.
- vii. Results of control evaluations.
- viii. Letter of confirmation and representation.
- ix. Analysis and tests of transactions, processes and account balances.
- x. Results of analytical auditing procedures.
- xi. The audit's final communication and management responses.
- xii. An audit notebook in which the internal auditor keeps the records of important matters, which he/she comes across while conducting the audit.
- xiii. Confirmation from third parties.
- xiv. Other necessary papers required for conducting the audit.

## **8.2. Control of Audit Records**

- 8.2.1. The audit report and working paper files should generally remain under the control of the Chief Internal Auditor or a delegate and should be accessible only to IT Audit Director, Team managers, IT Auditors, and any authorized person.
- 8.2.2. The request for access should be subject to the approval of the Chief Internal Auditor/ Chief Executive Officer in consultation with the Director-Legal Service as the case may be. If it is from the Bank's internal organ, other than internal audit, it can be approved by the Chief Internal Auditor.
- 8.2.3. Requests from external users should be approved by the Bank's Chief Executive Officer in consultation with the Director-Legal Service as the case may be, depending on the situation.
- 8.2.4. The same approval process will be followed for any request for access to records or audit files under the custody of internal audit process, in relation to consulting engagement, to

protect the Bank adequately and avoid potential misunderstandings involving requests for such document.

### 8.3. Access Control and Maintenance of Audit Records

8.3.1. Any entity shall not dispose of records at its disposal and should keep or maintain safe for the time period set by pertinent law. For easy reference, maintenance and access control of audit records, the Chief Internal Auditor is, therefore, responsible to:

- i. Maintain special (fraud) investigation reports under his/her safe custody; and
- ii. Maintain regular audit reports of assurance and consulting services in an archive close enough to his/her office for at least for **two** years after satisfactorily rectified or until conducting audit on the same **unit for the 2<sup>nd</sup> time**. Then, the report can be sent to the Bank's Central Archives where it should be kept for at least ten years pursuant to the pertinent directive no. sbb/76/2020 article no. 9.2.

### 8.4. Audit Files

8.4.1. All audit files must be given sequential reference numbers and be maintained in the Audit Report Register/Log to facilitate access. Numbers are selected in numeric order, with the first two digits indicating the fiscal year in which the audit was undertaken. The remaining digits represent the number of audits undertaken within that year. For example, audit 01/08 indicates that the audit has been conducted in 2008, and it is the first of that year.

8.4.2. The audit report log records the audit number, the type of audit, name of the team members, audit date, name of the auditee, and date the final report has been issued.

8.4.3. A Soft Copy of all audit reports should be maintained centrally to ease future references and other purposes until next audit time.

8.4.4. IT Audit shall maintain Current Audit File, which shall contain the following information:

- i. Copies of the previous audit reports, along with the reports on the corrective actions taken and correspondences made.
- ii. Copies of the documents that the audit team has collected.
- iii. Copies of the Audit Programs and any other related documents.
- iv. Audit report, including auditee responses and related correspondences.
- v. Engagement working papers.

- vi. Follow-up report; and
- vii. Other relevant documents.

8.4.5. The following Documents are parts of the Permanent Audit File:

- i. Mission statement and/or the goals/objectives of the Bank and the auditee
- ii. Policies and Procedures of the auditee
- iii. Circulars and Memoranda issued by the Bank.
- iv. Directives/Laws and Regulations issued by the Supervisory Authorities and the Government.
- v. Audit universe.
- vi. Organizational chart.
- vii. Process map (flow charts); and
- viii. Other relevant documents.

8.4.6. Current Audit Files should be pruned to make them handy. However, a copy of the previous audit report should at least be maintained, and the old files shall be handled as prescribed in item No.8.3 (ii) herein above.

## **Part Nine**

### **9. Miscellaneous provisions**

#### **9.1. Applicability of Internal Audit Procedure**

The articles or provisions of the Risk Based Internal Audit Procedure should be directly applicable to the matters of IT Audit activities in areas not specifically covered by this procedure.

#### **9.2. Revision of the Procedure**

IT Audit Procedure shall be revised every two years and whenever deemed necessary to revise this procedure.

#### **9.3. Effective Date**

This Risk Based IT Audit procedure enters into force effective **June 13, 2026**.

**ISSUED UNDER THE SIGNATURES OF:**

-----  
**Chairperson, Board of Directors**

## Sample Designs of Core Templates

The following are standard IT Audit Procedure Templates to ensure methodological consistency and process uniformity.

### Template 1

#### IT Audit Notification Format

##### A. Audit assignment memo

The following templates represent the official forms and formats used by the Cooperative Bank of Oromia IT Audit Function.

##### internal audit process - audit assignment memo

- **Audit Object:** \_\_\_\_\_
- **Audit No:** \_\_\_\_\_
- **Budgeted Days:** \_\_\_\_\_
- **Date Assigned:** \_\_\_\_\_

##### General Comments / Special Instructions:

[Enter any specific instructions for this engagement...]

##### Audit Objectives (in general terms):

[Enter high-level objectives...]

##### Internal Auditors Assigned:

[List names...]

##### Auditor in Charge of leading the team:

[Name of lead auditor...]

- **Prepared by:** \_\_\_\_\_ **Date:** \_\_\_\_\_
- **Approved by:** \_\_\_\_\_ **Date:** \_\_\_\_\_

##### B. Audit Notification Letter

**To:** [Process Owner]

**From:** Director of IT Audit / IT Audit Manager

**Date:** [Date]

**Subject:** Notification of IT Audit Engagement - [Audit object Name]

Dear [Name],

This letter serves to formally notify you that the IT Audit sub-process will commence an audit of [Audit object Name] on [Start Date].

**Objective:** To evaluate the adequacy and effectiveness of controls over [Brief Objective].

**Scope:** The audit will cover the period from [Date] to [Date] and include [Specific Systems/Locations].

**Audit Team:** [Lead Auditor Name], [Member Auditor Name].

Please nominate a primary point of contact for this engagement. An opening meeting is scheduled for [Date/Time].

## Template 2

### Audit Planning Memorandum (APM) Structure

| Section          | Field Description                                                  |
|------------------|--------------------------------------------------------------------|
| Project ID       | Unique Engagement Code (e.g., ITA-2026-001)                        |
| Background       | Overview of the system/process under review.                       |
| Risk Assessment  | Detailed identification of Inherent Risks and Control Environment. |
| Audit Objectives | Specific goals the engagement seeks to achieve.                    |
| Audit Scope      | Explicit boundaries (In-scope vs. Out-of-scope).                   |
| Resource Plan    | Allocated personnel, estimated hours, and budget.                  |
| Timeline         | Key milestones (Fieldwork, Draft Report, Final Exit).              |
| Approvals        | Signatures of IT Audit Director/Manager.                           |

## Template 3

### Information Request (RFI) Matrix

| Req #  | Document / Information Requested            | Purpose / Relevance                                      | Priority | Assigned To       | Status(received/pending/overdue) |
|--------|---------------------------------------------|----------------------------------------------------------|----------|-------------------|----------------------------------|
| RFI-01 | IT Organizational Chart & Job Descriptions  | To understand reporting lines and segregation of duties. | High     | HR / IT Manager   |                                  |
| RFI-02 | Data Center Access Logs (Last 6 Months)     | To test physical security controls over critical infra.  | Medium   | Facility Security |                                  |
| RFI-03 | Change Management Policy & Flowchart        | To verify the standard lifecycle for code deployments.   | High     | Change Manager    |                                  |
| RFI-04 | List of Terminated Users (Active Directory) | To select sample for access revocation testing.          | High     | IT Ops            |                                  |

### Template 4

#### A. Detailed Audit Program (Test Script Sample)

| Ref # | Control Objective          | Test Procedure (Audit Step)                                                           | Expected Result                                       | Result (Pass/Fail) | W/P Ref |
|-------|----------------------------|---------------------------------------------------------------------------------------|-------------------------------------------------------|--------------------|---------|
| CO-01 | User access is restricted. | Select a sample of 25 terminated users and verify access was revoked within 24 hours. | All sample users have "Disabled" status in AD.        | Pass               | WP-101  |
| CO-02 | Backups are successful.    | Review daily backup logs for the last 30 days for the Core Banking DB.                | No failed backup jobs without documented remediation. | Fail               | WP-205  |

#### B. Audit Program Template

Audit Object: \_\_\_\_\_ Audit Number: \_\_\_\_\_

1. Auditable Unit: [Name]
2. Areas to be Audited: [List]
3. Previous Audit Status: [History]
4. Assigned Team: [Members]
5. High-level Objectives: [Objectives]
6. Time Required:

| S/N | Phase        | Expected Days |
|-----|--------------|---------------|
| 1   | Pre-Auditing |               |
| 2   | Auditing     |               |
| 3   | Reporting    |               |

#### C. Internal Control Questionnaire (Icq)

[Detailed questionnaires customized per IT domain (e.g., Access Control, Change Management, Physical Security) ...]



### Template 5

#### Audit Finding Development Sheet (The 5 Cs)

| Attribute         | Detail                                                                               |
|-------------------|--------------------------------------------------------------------------------------|
| Condition         | What is the current state? (e.g., 5 firewall rules are overly permissive).           |
| Criteria          | What should be? (e.g., Bank Security Policy section 4.2 requires "Least Privilege"). |
| Cause             | Why did it happen? (e.g., Lack of periodic firewall rule review process).            |
| Consequence       | What is the risk? (e.g., Potential unauthorized access to the production segment).   |
| Corrective Action | Recommendation: (e.g., Implement quarterly rule review and remove identified rules). |

### Template 6

#### Follow-Up Validation Sheet

| Finding ID | Original Recommendation | Management Action Taken     | Auditor Validation Note                         | Status (closed/open) |
|------------|-------------------------|-----------------------------|-------------------------------------------------|----------------------|
| F-01       | Revoke old admin keys.  | All keys revoked on Jan 15. | Verified AWS IAM logs; keys are deleted.        |                      |
| F-02       | Update DR Plan.         | Draft submitted for review. | Document is incomplete; pending Board approval. |                      |

### Template 7

#### Audit Report (Draft/Final) Structure

| Report Section                                | Content Description                                                                                    |
|-----------------------------------------------|--------------------------------------------------------------------------------------------------------|
| I. Executive Summary                          | High-level assurance opinion, overall risk rating, and key achievements.                               |
| II. Audit Objectives & Scope                  | What was audited and what the engagement intended to achieve.                                          |
| III. Methodology                              | Reference to ITAF standards and sampling techniques used.                                              |
| IV. Detailed Findings and auditee's responses | Categorized list of observations (5 Cs) with corresponding risk ratings including auditee's responses. |
| V. Conclusion                                 | Final assessment of control adequacy for the audited process.                                          |
| VII. Appendices                               | Detailed data tables, RFI logs, or technical evidence extracts.                                        |

## Template 8

### ITAF Professional Standards Framework (5th Edition Reference)

As mandated by the Bank's Internal Audit Charter, all engagements must align with the ISACA Information Technology Assurance Framework (ITAF).

#### A. General Standards (1000 Series)

| Standard ID | Title                       | Core Objective                                                 |
|-------------|-----------------------------|----------------------------------------------------------------|
| 1001        | Audit Charter               | Establishing the formal mandate and authority.                 |
| 1002        | Organizational Independence | Ensuring the function is free from operational bias.           |
| 1003        | Auditor Objectivity         | Maintaining an impartial mindset in all assessments.           |
| 1004        | Reasonable Expectation      | Confirming the engagement can be successfully completed.       |
| 1005        | Due Professional Care       | Exercising diligence and professional skepticism.              |
| 1006        | Proficiency                 | Maintaining collective and individual competence.              |
| 1007        | Assertions                  | Reviewing claims against which the subject matter is assessed. |
| 1008        | Criteria                    | Selecting objective, relevant, and measurable benchmarks.      |

#### B. Performance Standards (1200 Series)

| Standard ID | Title                           | Core Objective                                                 |
|-------------|---------------------------------|----------------------------------------------------------------|
| 1201        | Risk Assessment in Planning     | Using a structured approach to prioritize audit resources.     |
| 1202        | Audit Scheduling                | Developing short- and long-term risk-based schedules.          |
| 1203        | Engagement Planning             | Defining nature, timing, and extent of procedures.             |
| 1204        | Performance and Supervision     | Ensuring adequate oversight and work quality.                  |
| 1205        | Evidence                        | Obtaining sufficient and appropriate evidence for conclusions. |
| 1206        | Using the Work of Other Experts | Managing reliance on external or internal specialists.         |
| 1207        | Irregularities and Illegal Acts | Considering fraud risk during every engagement.                |

#### C. Reporting Standards (1400 Series)

| Standard ID | Title                | Core Objective                                           |
|-------------|----------------------|----------------------------------------------------------|
| 1401        | Reporting            | Communicating results through a formal written report.   |
| 1402        | Follow-up Activities | Monitoring management's progress in addressing findings. |

### Template 9

#### Standard Risk Rating Criteria

A formal appendix defines the scoring methodology:

| Rating   | Definition                                                              | Remediation Expectation          |
|----------|-------------------------------------------------------------------------|----------------------------------|
| Critical | Immediate catastrophic risk requiring instant escalation to the Board.  | Immediate shutdown or mitigator. |
| High     | Significant exposure requiring remediation within 30-90 days.           | Management Action Plan required. |
| Medium   | Moderate exposure requiring prioritized action within 6 months.         | Quarterly follow-up tracking.    |
| Low      | Minor deviation or efficiency opportunity for management consideration. | Discretionary remediation.       |

### Template 10

#### IT Audit Engagement Checklist

##### A. Preliminary Survey Template

**Audit Object:** \_\_\_\_\_ **Audit Number:** \_\_\_\_\_

##### Introduction:

Per the Risk-Based IT Audit Guideline, a preliminary survey is conducted to:

- Establish familiarity with activities, risks, and controls.
- Identify areas for engagement emphasis.
- Invite suggestions from auditees.

##### General Information:

- Ref. procedures and documentation: [List]
- Ref. internal and external regulations: [List]
- List of incidents (excesses, shortages): [List]

##### Preliminary Survey Audit Check-list:

| No | Risks | Risk Level | Expected Controls |
|----|-------|------------|-------------------|
|----|-------|------------|-------------------|

## B. Master IT Audit Engagement Checklist

| Testing Domain | What to Test (Control Objective)   | How to Test (Audit Procedure)                        | Related Risks (If Control Fails) |
|----------------|------------------------------------|------------------------------------------------------|----------------------------------|
| Logic & Access | Authorized users only.             | Sample active users vs. HR/IT role request forms.    | Unauthorized disclosure; fraud.  |
| Change Mgt     | Tested and approved changes.       | Review UAT sign-offs and Change Board (CAB) minutes. | Instability; downtime.           |
| IT Operations  | Backed up and recoverable data.    | Review logs; observe a sample restoration drill.     | Data loss; non-compliance.       |
| DCM Security   | Restricted server room access.     | Inspect biometric/keycard logs; verify cameras.      | Physical tampering; theft.       |
| Vendor Risk    | Providers meet security standards. | Review SLA reports and SOC 2 audits.                 | Supply chain compromise.         |

## C. Standard Auditor Execution Checklists

### Opening meeting checklist

| Audit Phase: Planning | Requirement / Protocol                                   | Verification                                             |
|-----------------------|----------------------------------------------------------|----------------------------------------------------------|
| Introductions         | Formal introduction of the audit team and their roles.   | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Objective             | Clear explanation of the audit's intent and value-add.   | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Scope                 | Explicitly defined boundaries and systems to be tested.  | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Timeline              | Agreement on fieldwork start/end and reporting dates.    | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Logistics             | Identification of contact points and RFI upload process. | <input type="checkbox"/> Yes <input type="checkbox"/> No |

## D. Fieldwork quality & evidence checklist

| Evaluation Area | Quality Standard                                             | Verified                                                 |
|-----------------|--------------------------------------------------------------|----------------------------------------------------------|
| Traceability    | Can a third party re-perform the test?                       | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Sufficiency     | Is the sample size statistically relevant or risk-justified? | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Cross-Ref       | Are all findings linked to the APM and Audit Program?        | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Data Integrity  | Are screenshots annotated and sources identified?            | <input type="checkbox"/> Yes <input type="checkbox"/> No |

### E. Final report quality gate (pre-issuance)

| Final Review Step | Validation Criteria                                     | Status                                                   |
|-------------------|---------------------------------------------------------|----------------------------------------------------------|
| Fact-Check        | Has every observation been cleared with the auditee?    | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Rating Alignment  | Does the risk score match the institutional matrix?     | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Closure           | Are all RFIs closed or moved to "Outstanding"?          | <input type="checkbox"/> Yes <input type="checkbox"/> No |
| Opinion           | Is the assurance opinion clearly supported by evidence? | <input type="checkbox"/> Yes <input type="checkbox"/> No |

### Template 11

#### Document / System Request Format

- Requested by: [Name] Signature: \_\_\_\_\_
- Required Material & Purpose: [Description]
- Date of Request: \_\_\_\_\_
- Date of Return: \_\_\_\_\_

### Template 12

#### Audit Lead Time Evaluation

#### Formats To Evaluate Lead-Time of IT Audit Operations

| S/N | Team Members | Auditee Name | Standard Days | Challenge Days | Working Days Used | Start Date | End Date | Standard Avg | Used Avg | Remark |
|-----|--------------|--------------|---------------|----------------|-------------------|------------|----------|--------------|----------|--------|
|     |              |              |               |                |                   |            |          |              |          |        |
|     |              |              |               |                |                   |            |          |              |          |        |

- Employee Signature: \_\_\_\_\_ Date: \_\_\_\_\_
- Supervisor Signature: \_\_\_\_\_ Date: \_\_\_\_\_

### Template 13

#### Audit Work Paper Review Checklist

| Item                                               | Yes | No | Remark |
|----------------------------------------------------|-----|----|--------|
| Have all audit program steps been completed?       |     |    |        |
| Are reasons for omissions documented?              |     |    |        |
| Is every finding supported by evidential material? |     |    |        |
| Is the 5 Cs analysis adequate?                     |     |    |        |
| Are work papers responsive to the audit scope?     |     |    |        |

### Template 14

#### **Audit Rectification Status Follow-up Sheet**

| S/N | Finding No | Description | Not Rectified | Partially | Fully | Remark |
|-----|------------|-------------|---------------|-----------|-------|--------|
|     |            |             |               |           |       |        |

### Template 15

#### **Audit Productivity Measurement**

##### **Grading Elements:**

- Templates completed on schedule (5 points).
- Detailed audit program developed (10 points).
- Management informed of progress (5 points).
- Work papers correctly support conclusions (15 points).
- Report addresses all objectives (15 points).
- Quality of reporting and value added (40 points).

### Template 16

#### **Code of Conduct of Internal Auditors**

1. Integrity: Auditors shall perform work with honesty, diligence, and responsibility.
2. Objectivity: Auditors shall not participate in activities that impair unbiased assessment.
3. Confidentiality: Prudence in using and protecting acquired information.
4. Competency: Engagement only in services for which they have necessary knowledge/skills.

### Template 17

#### **Audit Customer Survey**

| Question                                   | Yes | No |
|--------------------------------------------|-----|----|
| Was an entrance interview held?            |     |    |
| Were goals and objectives discussed?       |     |    |
| Were auditors responsive to your concerns? |     |    |
| Were you informed of changes promptly?     |     |    |
| <b>Value Rating (1-5): [ ]</b>             |     |    |